

第9章 信息安全

随着信息化进程的深入和互联网的快速发展,网络化已经成为企业信息化的发展大趋势,信息资源也得到最大程度的共享。但是,紧随信息化发展而来的网络安全问题日渐突出,已成为信息时代人类共同面临的挑战。目前,危害计算机信息系统安全的事件频繁发生,而且有愈演愈烈之势,甚至会影响国家之间的战争形势,由既有战争方式转变为没有硝烟的网络战争。

如果计算机和网络系统的安全受到危害,将会危及国家安全,引起社会混乱,造成重大损失。系统分析师作为信息系统建设的挑大梁者,必须掌握系统安全知识,在进行系统分析与设计时,足够重视安全性分析,根据系统的环境约束和用户要求,结合当前技术的发展,为信息系统构筑“铜墙铁壁”,确保用户应用和数据的安全。

9.1 信息系统安全体系

对于一个信息系统网络,必须要从总体上进行规划,建立一个科学而全面的信息安全保障体系,从而实现信息系统的整体安全。一个全面的信息系统安全体系包含的内容是多方面的,应该能够解决信息系统存在的大部分安全威胁。目前,信息安全威胁主要有以下几个方面:

(1) 对系统稳定性和可靠性的破坏行为,包括从外部网络针对内部网络的攻击入侵行为和病毒破坏等。

(2) 大量信息设备的使用、维护和管理问题,包括违反规定的计算机、打印机和其他信息基础设施滥用,以及信息系统违规使用软件和硬件的行为。

(3) 知识产权和内部机密材料等信息存储、使用和传输的保密性、完整性和可靠性存在可能的威胁,其中尤其以信息的保密性存在威胁的可能性最大。

1. 系统安全分类

信息系统的安全是一个复杂的综合体,涉及系统的方方面面,主要包括实体安全、运行安全、信息安全和人员安全等几个部分。

(1) 实体安全。在信息系统中,计算机及相关设备、设施(含网络)统称为系统的实体。实体安全是指保护计算机设备、设施和其他媒体免遭地震、水灾、火灾、有害气体和其他环境事故(例如,电磁辐射等)破坏的措施和过程。实体安全又可分为环境安全、设备安全和媒体安全三个方面。

(2) 运行安全。运行安全包括系统风险管理、审计跟踪、备份与恢复、应急等4个方面的内容。运行安全是计算机信息系统安全的重要环节,其实质是保证系统的正常运行,不因偶然的或恶意的侵扰而遭到破坏,使系统可靠、连续地运行,服务不受中断。

(3) 信息安全。信息安全是指防止系统中的信息被故意或偶然的非法授权访问、更改、破坏或使信息被非法系统识别和控制等。简单地说,信息安全就是确保信息的保密性、完整性、

可用性和可控性。针对信息存在的形式和特点,信息安全可分为操作系统安全、数据库安全、网络安全、病毒防护、访问控制、数据加密和认证(鉴别)7个方面。

(4) 人员安全。人员安全主要包括计算机使用人员的安全意识、法律意识和安全技能等。

2. 系统安全体系结构

作为全方位的、整体的系统安全防范体系也是分层次的,不同层次反映了不同的安全问题,根据网络的应用现状和结构,可以将安全防范体系划分为物理层安全、操作系统安全、网络安全、应用安全和安全管理。

(1) 物理层安全。物理层的安全包括通信线路、物理设备和机房的安全等。物理层的安全主要体现在通信线路的可靠性、软硬件设备的安全性、设备的备份、防灾害能力、防干扰能力、设备的运行环境和不间断电源保障等。

(2) 操作系统安全。系统层的安全问题来自计算机网络内使用的操作系统的安全。主要表现在3个方面,一是由操作系统本身的缺陷带来的不安全因素,主要包括身份认证、访问控制和系统漏洞等;二是操作系统的安全配置问题;三是病毒对操作系统的威胁。

(3) 网络安全。网络层的安全问题主要体现在计算机网络方面,包括网络层身份认证、网络资源的访问控制、数据传输的保密与完整性、远程接入的安全、域名系统的安全、路由系统的安全、入侵检测的手段和网络设施防病毒等。

(4) 应用安全。应用层的安全问题主要由提供服务所采用的应用软件和数据的安全性产生,包括Web服务、电子邮件系统和DNS等。此外,还包括病毒对系统的威胁。

(5) 安全管理。安全管理包括安全技术和设备的管理、安全管理制度、部门与人员的组织规则等。管理的制度化极大程度地影响着整个计算机网络的安全,严格的安全管理制度、明确的部门安全职责划分与合理的人员角色配置,都可以在很大程度上降低其他层次的安全漏洞。

3. 安全保护等级

《计算机信息系统 安全保护等级划分准则》(GB 17859—1999)规定了计算机系统安全保护能力的5个等级,即用户自主保护级、系统审计保护级、安全标记保护级、结构化保护级和访问验证保护级。系统安全保护能力随着安全保护等级的提高逐渐增强。

(1) 用户自主保护级(第一级)。第一级的计算机信息系统可信计算机通过隔离用户与数据来实现,使用户具备自主安全保护的能力。它具有多种形式的控制能力,对用户实施访问控制,即为用户提供可行的手段,保护用户和用户组信息,避免其他用户对数据的非法读写与破坏。第一级适用于普通内联网用户。

(2) 系统审计保护级(第二级)。与第一级相比,第二级的计算机信息系统可信计算机实施了粒度更细的自主访问控制,它通过登录规程、审计与安全性相关事件和隔离资源,使用户对自己的行为负责。第二级适用于通过内联网或互联网进行商务活动,需要保密的非重要单位。

(3) 安全标记保护级(第三级)。第三级的计算机信息系统可信计算机具有系统审计保护级的所有功能。此外,还提供有关安全策略模型、数据标记以及主体对客体强制访问控制的非形式化描述;具有准确地标记输出信息的能力;消除通过测试发现的任何错误。第三级适用于地

方各级国家机关、金融机构、邮电通信、能源与水源供给部门、交通运输、大型工商与信息技术企业、重点工程建设等单位。

(4) 结构化保护级（第四级）。第四级的计算机信息系统可信计算机建立于一个明确定义的形式化安全策略模型之上，它要求将第三级系统中的自主和强制访问控制扩展到所有主体与客体。此外，还要考虑隐蔽通道。本级的计算机信息系统可信计算机必须结构化为关键保护元素和非关键保护元素。计算机信息系统可信计算机的接口也必须明确定义，使其设计与实现能经受更充分的测试和更完整的复审。加强了鉴别机制，支持系统管理员和操作员的职能，提供可信设施管理，增强了配置管理控制。系统具有相当的抗渗透能力。第四级适用于中央级国家机关、广播电视部门、重要物资储备单位、社会应急服务部门、尖端科技企业集团、国家重点科研机构和国防建设等部门。

(5) 访问验证保护级（第五级）。第五级的计算机信息系统可信计算机满足访问监控器需求。访问监控器仲裁主体对客体的全部访问。访问监控器本身是抗篡改的，而且必须足够小，能够分析和测试。为了满足访问监控器需求，计算机信息系统可信计算机在其构造时，排除了那些对实施安全策略来说并非必要的代码；在设计和实现时，从系统工程角度将其复杂性降低到最小程度。支持安全管理员职能；扩充审计机制，当发生与安全相关的事件时发出信号；提供系统恢复机制。系统具有很高的抗渗透能力。第五级适用于国防关键部门和依法需要对计算机信息系统实施特殊隔离的单位。

4. 系统安全保障系统

针对当前复杂、技术手段各异的安全威胁，要建立一个完整的系统安全保障体系，应该包含以下几个方面的内容：

(1) 建立统一的身份认证体系。身份认证是信息交换最基础的要素，如果不能确认交换双方的实体身份，那么系统安全就根本无从得到保证。身份认证的含义是广泛的，其泛指一切实体的身份，包括人、计算机、设备和应用程序等，只有确认了所有这些信息在存储、使用和传输过程中可能涉及的实体，系统的安全性才有可能得到基本保证。

(2) 建立统一的安全管理体系。建立对所有实体有效的管理体系，能够对计算机网络系统中的所有计算机、输出端口、存储设备、网络、应用程序和其他设备进行有效的集中管理，从而有效管理和控制计算机网络中存在的安全风险。安全管理体系的建立主要集中在技术性系统的建立上，同时，也应该建立相应的管理制度，才能使安全管理系统得到有效实施。

(3) 建立规范的安全保密体系。信息的保密性是一个大型信息应用网络不可缺少的需求，所以，必须建立符合规范的信息安全保密体系，这个体系不仅应该提供完善的技术解决方案，也应该建立相应的信息保密管理制度。

(4) 建立完善的网络边界防护体系。重要的计算机网络一般会与 Internet 进行一定程度的分离，在内部信息网络和 Internet 之间存在一个网络边界。必须建立完善的网络边界防护体系，使得内部网络既能够与外部网络进行信息交流，同时也能防止从外网发起的对内部网络的攻击等安全威胁。

此外，从国家角度考虑，要加快信息系统安全立法，建立信息安全法制体系，这样才能做

到有法可依，有法必依；建立国家信息安全组织管理体系，加强国家信息安全机构及职能；建立高效能、职责分工明确的行政管理和业务组织体系；建立信息系统安全标准和评估体系；建立国家信息安全技术保障体系，使用科学技术实施安全的防护保障。

9.2 数据安全与保密

为用户提供安全、可靠的保密通信，是信息系统安全最为重要的内容，尽管系统安全不仅仅局限于保密性，但不能提供保密性的系统肯定是不安全的。系统的保密性机制除了为用户提供保密通信以外，也是其他安全机制的基础。例如，访问控制中登录口令的设计、安全通信协议的设计和数字签名的设计等，都离不开密码机制。

9.2.1 数据加密技术

加密是指对数据进行编码变换，使其看起来毫无含义，但同时却仍可以保持其可恢复的形式过程。在这个过程中，被变换的数据称为明文，它可以是一段有意义的文字或者数据，变换后的数据称为密文。加密机制有助于保护信息的机密性和完整性，有助于识别信息的来源，它是最广泛使用的安全机制。

传统加密算法主要包括代换加密和置换加密两种。代换加密的方法是，首先构造一个或多个密文字母表，然后用密文字母表中的字母或字母组来代替明文字母或字母组，各字母或字母组的相对位置不变，但其本身改变了；置换加密将明文中的字母重新排列，字母本身不变，但其位置改变了。传统加密算法具有设计简单的特点，曾经得到大量使用。但它们的一个主要弱点是，算法和密钥密切相关。攻击者可以利用字母的统计和语言学知识，破译密文相对容易，尤其是在计算机技术高度发展的今天，可以充分利用计算机进行密文分析。

从20世纪60年代开始，随着电子技术、计算机技术的迅速发展，以及结构代数、可计算性和计算复杂性理论等学科的研究，密码学又进入了一个新的发展时期。在20世纪70年代后期，对称加密算法和非对称加密算法的出现，成为了现代密码学发展史中的两个重要里程碑。

1. 对称加密算法

对称加密算法也称为私钥加密算法，是指加密密钥和解密密钥相同，或者虽然不同，但从其中的任意一个可以很容易地推导出另一个。其优点是具有很高的保密强度，但密钥的传输需要经过安全可靠的途径。对称加密算法有两种基本类型，分别是分组密码和序列密码。分组密码是在明文分组和密文分组上进行运算，序列密码是对明文和密文数据流按位或字节进行运算。

常见的对称加密算法包括瑞士的国际数据加密算法（International Data Encryption Algorithm, IDEA）和美国的数据加密标准（Data Encryption Standard, DES）。

2. 非对称加密算法

非对称加密算法也称为公钥加密算法，是指加密密钥和解密密钥完全不同，其中一个为公钥，另一个为私钥，并且不可能从任何一个推导出另一个。它的优点在于可以适应开放性的使

用环境，可以实现数字签名与验证。

最常见的非对称加密算法是 RSA，它的密钥长度为 512 位，保密性取决于数学上将一个数分解为两个素数的问题的难度，根据已有的数学方法，其计算量极大，破解很难。但是加密/解密时要进行大指数模运算，因此加密/解密速度很慢，主要用在数字签名中。

9.2.2 认证技术

信息的完整性一方面是指信息在利用、传输、存储等过程中不被删除、修改、伪造、乱序、重放和插入等，另一方面是指信息处理方法的正确性。不适当的操作（例如，误删除文件等）有可能造成重要文件的丢失。完整性和保密性不同，保密性要求信息不被泄露给未授权的人，而完整性则要求信息不受到各种原因的破坏。

认证（authentication）又称为鉴别或确认，它是证实某事物是否名副其实或是否有效的过程。认证和加密的区别在于，加密用于确保数据的保密性，阻止非法者的被动攻击，例如，截取和窃听等；而认证用于确保数据发送者和接收者的真实性和消息的完整性，阻止非法者的主动攻击，例如，冒充、篡改和重放等。认证往往是许多应用系统中安全保护的第一道防线，因而极为重要。

1. 数字签名

数字签名是附加在数据单元上的一些数据，或是对数据单元所作的密码变换。这种数据或变换允许数据单元的接收者用以确认数据单元的来源和数据单元的完整性并保护数据，防止被人（例如，接收者）进行伪造。基于对称加密算法和非对称加密算法都可以获得数字签名，但目前主要是使用基于非对称加密算法的数字签名，包括普通数字签名和特殊数字签名。普通数字签名算法有 RSA、ElGamal、Fiat-Shamir、Des/DSA、椭圆曲线数字签名算法和有限自动机数字签名算法等；特殊数字签名算法有盲签名、代理签名、群签名、不可否认签名、公平盲签名、门限签名和具有消息恢复功能的签名等，它与具体应用场景密切相关。显然，数字签名的应用涉及法律问题，美国联邦政府基于有限域上的离散对数问题制定了自己的数字签名标准（Digital Signature Standard, DSS）。

数字签名的主要功能是保证信息传输的完整性、发送者的身份认证、防止交易中的抵赖发生。因此，不管使用哪种算法，数字签名必须保证以下三点：

- （1）接收者能够核实发送者对数据的签名，这个过程称为鉴别。
- （2）发送者事后不能抵赖对数据的签名，这称为不可否认。
- （3）接收者不能伪造对数据的签名，这称为数据的完整性。

2. 数字签名算法

（1）杂凑算法。杂凑算法是主要的数字签名算法，它是利用散列（Hash）函数（哈希函数、杂凑函数）进行数据的加密。单向 Hash 函数提供了这样一种计算过程：输入一个长度不固定的字符串，返回一串定长的字符串，这个返回的字符串称为消息摘要（Message Digest, MD），也称为 Hash 值或散列值。Hash 函数主要可以解决以下两个问题，首先，在某一特定的时间内，无法查找经 Hash 操作后生成特定 Hash 值的原消息；其次，无法查找两个经 Hash 操作后生成相

同 Hash 值的不同消息。这样,在数字签名中就可以解决验证签名、用户身份验证和不可抵赖性的问题。

(2) 消息摘要算法。消息摘要算法(Message Digest algorithm 5, MD5)用于确保信息传输完整一致,经 MD2、MD3 和 MD4 发展而来。它的作用是把大容量信息在用数字签名软件签署私人密钥前“压缩”成一种保密的格式,即将一个任意长度的字符串变换成一个定长的大数)。不管是 MD2、MD4 还是 MD5,它们都需要获得一个随机长度的信息并产生一个 128 位的消息摘要。MD5 以 512 位分组来处理输入的信息,且每个分组又被划分为 16 个 32 位子分组,经过一系列的处理后,算法的输出由 4 个 32 位分组组成,将这 4 个 32 位分组级联后,将生成一个 128 位的散列值。

(3) 安全散列算法。安全散列算法(Secure Hash Algorithm, SHA)能计算出一个数字信息所对应的长度固定的字符串(消息摘要),它对长度不超过 264 位的消息产生 160 位的消息摘要。这些算法之所以被称作“安全”,是基于以下两点:第一,由消息摘要反推原输入信息,从计算理论上来说是很困难的;第二,想要找到两组不同的信息对应到相同的消息摘要,从计算理论上来说也是很困难的,因为任何对输入信息的变动,都有很高的概率导致其产生的消息摘要不同。

SHA 家族的 5 个算法分别是 SHA-1、SHA-224、SHA-256、SHA-384 和 SHA-512,由美国国家安全设计,并由美国国家标准与技术研究院发布,是美国的政府标准。后四者有时统称为 SHA-2。SHA-1 在许多安全协议中广为使用,包括传输层安全协议(Transport Layer Security, TLS)和安全套接层(Secure Sockets Layer, SSL)、优良保密协议(Pretty Good Privacy, PGP)、安全外壳(Secure Shell, SSH)、安全/多功能 Internet 邮件扩展(Secure/Multipurpose Internet Mail Extensions, S/MIME)和互联网安全协议(Internet Protocol Security, IPSec)等,SHA-1 曾被视为 MD5 的后继者。

3. 数字证书

数字证书又称为数字标识,是由认证中心(Certificate Authority, CA)签发的对用户的公钥的认证。数字证书的内容应包括 CA 的信息、用户信息、用户公钥、CA 签发时间和有效期等。目前,国际上对证书的格式和认证方法遵从 X.509 体系标准。

在 X.509 格式中,数字证书通常包括版本号、序列号(CA 下发的每个证书的序列号都是唯一的)、签名算法标识符、发行者名称、有效期、主体名称、主体的公钥信息、发行者唯一识别符、主体唯一识别符、扩充域、发行者签名(就是 CA 用自己的私钥对上述数据进行数字签名的结果,也可以理解为 CA 中心对用户证书的签名)等信息。

任何一个用户只要得到 CA 的公钥,就可以得到 CA 为该用户签署的数字证书。因为证书是不可伪造的,因此,对于存放证书的目录无须施加特别的保护。如果两个用户使用的是不同 CA 发放的证书,则无法直接使用证书;但如果两个 CA 之间已经安全地交换了公开密钥,则可以使用证书链来完成通信。当数字证书过了有效期、用户私钥已泄露、用户放弃使用原 CA 的服务、CA 私钥泄露等,都需要吊销证书,这时,CA 会维护一个证书撤销列表(Certificate Revocation List, CRL),供用户查询。

4. 身份认证

用户的身份认证是许多应用系统的第一道防线，其目的在于识别用户的合法性，从而阻止非法用户访问系统。身份识别对确保系统和数据的安全保密是极其重要的。目前，计算机网络系统中常用的身份认证方式主要有以下几种：

（1）口令认证。用户名/密码是最简单也是最常用的身份认证方法，密码是由用户自己设定的，只有用户自己才知道。只要能够正确输入密码，计算机就认为操作者就是合法用户。实际上，由于许多用户为了防止忘记密码，经常使用诸如生日、电话号码等容易被猜测的字符串作为密码，或者将密码抄在纸上，放在一个自认为安全的地方。这样，很容易造成密码泄露，即使能保证用户密码不被泄露，由于密码是静态的数据，在验证过程中需要在网络中传输，而每次验证使用的信息都是相同的，很容易被驻留在内存中的木马程序或网络中的监听设备截获。因此，从安全性上讲，用户名/密码方式是一种极不安全的身份认证方式。

（2）动态口令认证。动态口令技术是一种让用户密码按照时间或使用次数不断变化、每个密码只能使用一次的技术。它采用一种称为动态令牌的专用硬件，内置电源、密码生成芯片和显示屏，密码生成芯片运行专门的密码算法，根据当前时间或使用次数生成当前密码并显示在显示屏上。认证服务器采用相同的算法计算当前的有效密码。用户使用，只需要将动态令牌上显示的当前密码输入计算机，即可实现身份认证。由于每次使用的密码必须由动态令牌来产生，只有合法用户才持有该硬件，所以，只要通过密码验证就可以认为该用户的身份是可靠的。而用户每次使用的密码都不相同，即使黑客截获了一次密码，也无法利用这个密码来仿冒合法用户的身份。

动态口令技术采用一次一密的方法，有效保证了用户身份的安全性。但是，如果客户端与服务器端的时间或次数不能保持良好的同步，就可能发生合法用户无法登录的问题。并且用户每次登录时需要通过键盘输入一长串无规律的密码，一旦输错就要重新操作，使用起来非常不方便。

（3）生物特征识别。生物特征识别是通过可测量的身体或行为等生物特征进行身份认证的一种技术。生物特征分为身体特征和行为特征两类，身体特征包括指纹、掌型、视网膜、虹膜、人体气味、脸型、手的血管和脱氧核糖核酸（Deoxyribonucleic acid, DNA）等；行为特征包括签名、语音和行走步态等。目前，部分学者将视网膜识别、虹膜识别和指纹识别等归为高级生物识别技术，将掌型识别、脸型识别、语音识别和签名识别等归为次级生物识别技术，将血管纹理识别、人体气味识别、DNA识别等归为深奥的生物识别技术。

9.2.3 密钥管理体制

密钥是加密算法中的可变部分，在采用加密技术保护的信息系统中，其安全性取决于密钥的保护，而不是对算法或硬件保护。密码机制可以公开，密码设备可能丢失，但同一型号的密码机仍可继续使用。然而，密钥一旦丢失或出错，不但合法用户不能提取信息，而且可能为非法用户窃取信息提供了机会。因此，密钥的管理是关键问题。

密钥管理是指处理密钥自产生到销毁的整个过程中的有关问题，包括系统的初始化、密钥的产生、存储、备份/恢复、装入、分配、保护、更新、控制、丢失、吊销和销毁等。当前，

主要的密钥管理体制有三种，分别是适用于封闭网、以传统的密钥管理中心为代表的密钥管理基础设施（Key Management Infrastructure, KMI）机制，适用于开放网的公钥基础设施（Public Key Infrastructure, PKI）机制和适用于规模化专用网的种子化公钥（Seeded public-Key, SPK）机制。

1. KMI 机制

KMI 设定一个密钥分发中心（Key Distribution Center, KDC）来负责发放密钥，这种结构经历了从静态分发到动态分发的发展过程，是密钥管理的重要手段。静态分发是预配置技术，动态分发是“请求、分发”机制，即与物理分发相对应的电子分发，一般用于建立实时通信中的会话密钥，在一定意义上缓解了密钥管理规模化的矛盾。无论是静态发放或是动态发放，都基于秘密信道（物理通道）进行，其特点归纳如表 9-1 所示。

表 9-1 KMI 密钥分发机制

分发类型	技 术	特 点
静态分发	点对点分发	可用对称加密或非对称加密实现。对称加密分发是最简单、有效的密钥管理技术，能为鉴别提供可靠的参数，但不能提供不可否认服务。有数字签名要求时，则需要用非对称加密实现
	一对多分发	可用对称加密或非对称加密实现，是点对点配置的扩展。KDC 保留所有密钥，而用户端只保留自己的密钥。这是银行清算、军事指挥、数据库系统中的主流技术，也是建立秘密通道的主要方法
	网格状分发	也称为端端密钥，可用对称加密或非对称加密实现。密钥配置量为 C_n^2 ，其中 n 为用户端的数量
动态分发	对称加密分发	首先用静态分发方式下的星形密钥配置，在此基础上解决会话密钥的分发。这种密钥分发方式简单易行
	非对称加密分发	将公私和私钥都当作秘密变量。也可以将公钥和私钥分开，只将私钥当作秘密变量，公钥当作公开变量

2. PKI 机制

PKI 是一种遵循既定标准的密钥管理平台，它能够为所有网络应用提供加密和数字签名等服务，以及所必需的密钥和证书管理体系。PKI 机制解决了分发密钥时依赖秘密信道的问题。

完整的 PKI 系统必须具有 CA、数字证书库、密钥备份及恢复系统、证书作废系统和应用接口等基本构成部分。PKI 与 KMI 的比较如表 9-2 所示。

表 9-2 PKI 与 KMI 的比较

比 较 项 目	PKI	KMI
作用特性	良好的扩展性，适于开放业务	很好的封闭性，适于专用业务
服务功能	只提供数字签名服务	提供数据加密和数字签名功能
信任逻辑	第三方管理模式	集中式的主管方管理模式
负责性	个人负责的技术体系	单位负责制
应用角度	主外	主内

PKI 的基础技术包括加密、数字签名、数据完整性机制、数字信封、双重数字签名等。其中，数字信封是用加密技术来保证只有规定的特定接收人才能阅读通信的内容。使用数字信封技术时，信息发送方采用对称密钥来加密信息内容，然后将此对称密钥用接收方的公钥加密（这部分称为数字信封）之后，将它和加密后的信息一起发送给接收方；接收方先用相应的私钥打开数字信封，得到对称密钥，然后使用对称密钥解开加密信息。这种技术的安全性相当高。

3. SPK 机制

为了更好地解决密钥管理的问题，研究人员又提出了 SPK 体系。SPK 机制可以通过以下两种方法实现：

（1）多重公钥（Lapped Public Key, LPK），用 RSA 算法实现。多重公钥有两个缺点，一是将种子私钥以原码形式分发给署名用户；二是层次越多，运算时间越长。

（2）组合公钥（Combined Public Key, CPK），用 DLP 或 ECC 实现。CPK 克服了 LPK 的两个缺点，私钥是经组合以后的变量，不暴露种子，公钥的运算几乎不占时间，是一种比较理想的密钥管理解决方案。

9.3 通信与网络安全技术

网络安全是系统的核心。计算机网络作为信息的主要收集、存储、分配、传输和应用的载体，其安全对整个系统的安全起着至关重要甚至是决定性的作用。网络安全的基础是需要具有安全的网络体系结构和网络通信协议。但遗憾的是，今天的 Internet 不论是其体系结构还是通信协议，都具有各种各样的安全漏洞，由此而带来的安全事故也层出不穷。

当然，任何一种体系结构和通信协议，都不可能尽善尽美、没有漏洞，利用网络进行的攻击与反攻击、控制与反控制永远不会停止。因此，系统分析师要熟练掌握网络安全技术，针对网络安全需求，采用相应的措施。

9.3.1 防火墙

防火墙（firewall）是一种隔离控制技术，在不同网域之间设置屏障，阻止对信息资源的非法访问，也可以阻止重要信息从内部网络中非法输出。作为 Internet 的安全性保护措施，防火墙已经得到广泛的应用。通常，企业为了维护内部的信息系统安全，在企业网和 Internet 之间设立防火墙。企业信息系统对于来自 Internet 的访问，采取有选择的接收方式。它可以允许或禁止一类具体的 IP 地址访问，也可以接收或拒绝 TCP/IP 上的某一类具体的应用。

防火墙是位于两个或多个网络之间，执行访问控制策略的一个或一组系统，是一类防范措施的总称。防火墙通常放置在外部和内部网络的中间，执行网络边界的过滤封锁机制。在某些情况下，防火墙以专门的硬件形式出现，它是安装了防火墙软件，并针对安全防护进行了专门设计的网络设备，本质上还是软件在进行控制。

1. 防火墙的功能

如果没有防火墙，整个内部网络的安全性就完全依赖于每台计算机，因此，所有的计算机

在安全水平方面都必须达到一致的高度。也就是说,整个网络的安全水平是由安全水平最低的那台计算机决定的,这就是所谓的“木桶原理”。网络规模越大,对计算机进行管理,使它们达到统一的安全水平级别就越不容易。

如果采用了防火墙,内部网络中的计算机将不再直接暴露给来自 Internet 的攻击。因此,对整个内部网络的安全管理就变成了防火墙的安全管理,这样,使安全管理变得更为方便和易于控制,也使内部网络更加安全。具体来说,防火墙一般具有访问控制功能、内容控制功能、全面的日志功能、集中管理功能、自身的安全和可用性、流量控制、网络地址转换、虚拟专用网(Virtual Private Network, VPN)等功能。

2. 防火墙的分类

从总体上来说,防火墙技术可分为网络级防火墙和应用级防火墙两类。网络级防火墙用来防止整个网络出现外来非法的入侵。例如,分组过滤和授权服务器就属于这一类。前者检查所有流入本网络的信息,然后拒绝不符合事先制定好的一套准则的数据;而后者则检查用户的登录是否合法。应用级防火墙由应用程序进行接入控制,通常使用应用网关或代理服务器来区分各种应用。例如,可以只允许 WWW 应用,而阻止 FTP 应用。

在实际应用中,可以根据不同的应用对防火墙进行更加详细的划分,一般可以分为包过滤型防火墙、电路级网关型防火墙、应用网关型防火墙、代理服务型防火墙、状态检测型防火墙和自适应代理型防火墙。

3. 防火墙的体系结构

从体系结构上看,防火墙可以有多种实现模式,例如,宿主机模式、屏蔽主机模式和屏蔽子网模式等。

(1) 双宿/多宿主机模式。双宿/多宿主机模式是一种拥有两个或多个连接到不同网络上的网络接口的防火墙,如图 9-1 所示。通常用一台装有两块或多块网卡的堡垒主机做防火墙,两块或多块网卡各自与内部网和外部网相连,一般采用代理服务的办法,必须禁止网络层的路由功能。

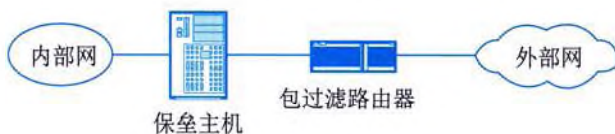


图 9-1 双宿/多宿主机模式

(2) 屏蔽主机模式。屏蔽主机模式的防火墙由包过滤路由器和堡垒主机组成,如图 9-2 所示。

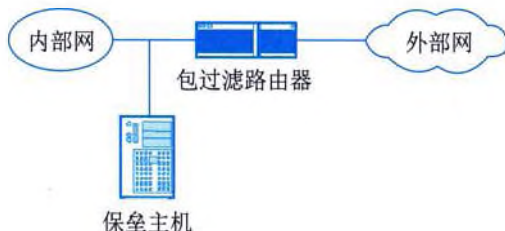


图 9-2 屏蔽主机模式

屏蔽主机模式的主要特点是，在防火墙中，将堡垒主机安装在内部网络上，通常在路由器上设立过滤规则，并使这个堡垒主机成为从外部网络唯一可直接到达的主机，这确保了内部网络不受未被授权的外部用户的攻击。屏蔽主机防火墙实现了网络层和应用层的安全，因此比单独的包过滤或应用网关代理更安全。在这种模式下，过滤路由器是否配置正确是防火墙安全与否的关键，如果路由表遭到破坏，堡垒主机就可能被越过，使内部网完全暴露。

(3) 屏蔽子网模式。屏蔽子网模式采用了两个包过滤路由器和一个堡垒主机，在内外网络之间建立一个被隔离的子网，称为非军事区（Demilitarized Zone, DMZ）或边界网络（Perimeter Network），如图 9-3 所示。



图 9-3 屏蔽子网模式

屏蔽子网模式的特点是，网络管理员将堡垒主机、Web 服务器、Mail 服务器等公用服务器放在 DMZ 中。内部网络和外部网络均可访问屏蔽子网，但禁止它们穿过屏蔽子网通信。在这一配置中，即使堡垒主机被入侵者控制，内部网仍能受到内部包过滤路由器的保护。多个堡垒主机运行各种代理服务，可以更有效地提供服务。

当然，防火墙还可能存在着其他的结构模式，例如，一个堡垒主机和一个 DMZ、合并 DMZ 的内部路由器和外部路由器、使用多个堡垒主机、使用多重宿主机与屏蔽子网等。在实际应用中，需要按照网络环境的要求来构造防火墙。

4. 防火墙的局限性

防火墙对企业内部网实现集中的安全管理，可以强化网络安全策略，能防止非授权用户进入内部网络，可以方便地监视网络的安全性并报警，可以作为部署 NAT 的地点，利用 NAT 技术，缓解地址空间的短缺，隐藏内部网的结构。同时，由于所有的访问都必须经过防火墙，因此，防火墙是审计和记录网络的访问和使用的最佳措施。然而，防火墙的使用也有一定的局限性，列举如下：

(1) 为了提高安全性，限制或关闭一些有用但存在安全缺陷的网络服务，给用户带来了使用上的不便。

(2) 目前，防火墙对于来自网络内部的攻击还无能为力。作为一种被动的防护手段，防火墙不能阻止 Internet 不断出现的新的威胁和攻击，不能有效地防范数据驱动式攻击。

(3) 防火墙不能防范不经过防火墙的攻击，例如，内部网用户通过串行线路网际协议（Serial Line Internet Protocol, SLIP）或点对点协议（Point to Point Protocol, PPP）直接进入 Internet。

(4) 防火墙对用户不完全透明,可能带来传输延迟、瓶颈和单点失效等问题。

(5) 防火墙不能完全防止受病毒感染的文件或软件的传输,由于病毒的种类繁多,如果要让防火墙完成对所有病毒代码的检查,防火墙的效率就会降低到不能忍受的程度。

总之,防火墙只是整个网络安全防护的一个部分,它需要与其他防护措施和技术配合使用,例如,密码技术、访问控制、权限管理和病毒防治等,才能解决内部网安全问题,并最终提供一套一体化的解决方案。

9.3.2 虚拟专用网

虚拟专用网(Virtual Private Network, VPN)是企业网在 Internet 等公共网络上的延伸,通过一个私有的通道在公共网络上创建一个安全的私有连接。因此,从本质上说,VPN 是一个虚信道,它可用来连接两个专用网,通过可靠的加密技术保证其安全性,并且是作为公共网络的一部分存在的。图 9-4 是一个 VPN 构成的原理示意图。

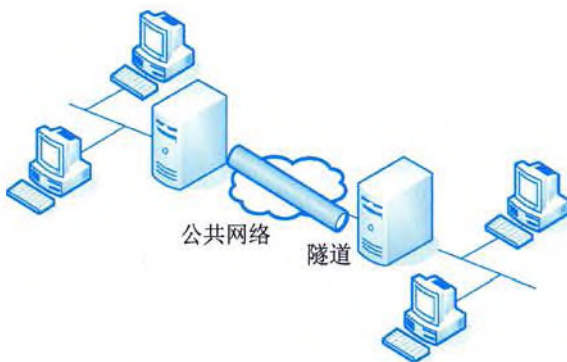


图 9-4 VPN 原理示意图

1. VPN 的关键技术

目前,VPN 主要采用 5 项技术来保证安全,它们分别是隧道技术、加解密技术、密钥管理技术、身份认证技术和访问控制技术。

(1) 隧道技术。隧道技术是 VPN 的基本技术,类似于点对点连接技术,它在公用网建立一条数据通道(隧道),让数据包通过这条隧道传输。

(2) 加解密技术。加解密技术是数据通信中一项较成熟的技术,VPN 可直接利用现有技术。

(3) 密钥管理技术。密钥管理技术的主要任务是如何在公用数据网上安全地传递密钥而不会被窃取。

(4) 身份认证技术。身份认证技术通常使用名称与密码或卡片式认证等方式。

(5) 访问控制技术。访问控制技术是由 VPN 服务的提供者根据在各种预定义的组中的用户身份标识,来限制用户对网络信息或资源的访问控制的机制。

2. PPP 会话过程

PPP 拨号会话过程可以分成 4 个不同的阶段,分别是创建 PPP 链路、用户验证、PPP 回叫控制和调用网络层协议。在用户验证阶段,客户 PC 会将用户的身份发送给网络接入服务

器（Network Access Server，NAS）。该阶段使用一种安全认证方式，以避免第三方窃取数据或冒充远程客户接管与客户端的连接。大多数 PPP 方案只提供有限的认证方式，包括口令认证协议（Password Authentication Protocol，PAP）和挑战握手认证协议（Challenge Handshake Authentication Protocol，CHAP）。

9.3.3 安全协议

在保证计算机网络系统的安全方面，安全协议起核心作用，主要包括 IPSec、SSL、PGP 和安全套接层上的超文本传输安全协议（Hypertext Transfer Protocol over Secure Socket Layer，HTTPS）等。

1. SSL

SSL 是一个传输层的安全协议，用于在 Internet 上传送机密文件。SSL 协议由握手协议、记录协议和警报协议组成。

SSL 握手协议用来在客户与服务器真正传输应用层数据之前建立安全机制，当客户与服务器第一次通信时，双方通过握手协议在版本号、密钥交换算法、数据加密算法和 Hash 算法上达成一致，然后互相验证对方身份，最后使用协商好的密钥交换算法产生一个只有双方知道的秘密信息，客户和服务器各自根据该秘密信息，产生数据加密算法和 Hash 算法参数；SSL 记录协议根据握手协议协商的参数，对应用层送来的数据进行加密、压缩和计算消息鉴别码，然后经传输层发送给对方；SSL 警报协议用来在客户和服务器之间传递 SSL 出错信息。

SSL 主要提供三个方面的服务，分别是用户和服务器的合法性认证、加密数据以隐藏被传送的数据和保护数据的完整性。SSL 使用 40 位关键字作为 RC4 流加密算法，这对于商业信息的加密是合适的。SSL 是一个保证计算机通信安全的协议，对通信对话过程进行安全保护，其实现过程主要经过如下几个阶段：

（1）接通阶段。客户机通过网络向服务器打招呼，服务器回应。

（2）密码交换阶段。客户机与服务器之间交换双方认可的密码，一般选用 RSA 密码算法，也有的选用 Diffie-Hellman 和 Fortezza-KEA 密码算法。

（3）会谈密码阶段。客户机器与服务器间产生彼此交谈的会谈密码。

（4）检验阶段。客户机检验服务器取得的密码。

（5）客户认证阶段。服务器验证客户机的可信度。

（6）结束阶段。客户机与服务器之间相互交换结束的信息。

发送时信息用对称密钥加密，对称密钥用非对称算法加密，再把两个捆绑在一起传送过去。接收的过程与发送的过程正好相反，先打开有对称密钥的加密包，再用对称密钥解密。因此，SSL 协议也可用于安全电子邮件。

2. HTTPS

HTTPS 是以安全为目标的 HTTP 通道，简单地说，HTTPS 是 HTTP 的安全版。SSL 极难窃听，可对中间人攻击提供一定的合理保护。

HTTPS 是一个统一资源标识符（Uniform Resource Identifier，URI）语法体系，句法类同

HTTP 体系,用于安全的 HTTP 数据传输。HTTPS 实际上应用了 SSL 作为 HTTP 应用层的子层,HTTPS 使用端口 443 (也可以指定其他 TCP 端口),而不是像 HTTP 那样使用端口 80 来和 TCP/IP 进行通信。HTTPS 和 SSL 支持使用 X.509 数字认证,如果需要的话,用户可以确认发送者是谁。也就是说,它的主要作用有两个:一个是建立一个信息安全通道,来保证数据传输的安全;另一个就是确认网站的真实性。

3. PGP

PGP 是一个基于 RSA 的邮件加密软件,可以用它对邮件保密以防止非授权者阅读,它还能对邮件加上数字签名,从而使收信人可以确信邮件发送者。PGP 的基本原理是,先用对称密钥加密传送的信息,再将该对称加密密钥以接收方的公钥加密,组成数字信封,并将此密钥交给公正的第三方保管;然后,将此数字信封传送给接收方。接收方必须先以自己的私钥将数字信封拆封,以获得对称解密密钥,再以该对称解密密钥解出真正的信息,兼顾了方便与效率。

PGP 还可用于文件存储的加密。PGP 承认两种不同的证书格式,分别是 PGP 证书和 X.509 证书。其中,一份 PGP 证书包括版本号、证书持有者的公钥、证书持有者的信息(例如,姓名、用户 ID、照片等)、证书拥有者的数字签名、证书的有效期和密钥首选的对称加密算法等内容。

4. IPSec

IPSec 是一个工业标准网络安全协议,为 IP 网络通信提供透明的安全服务,保护 TCP/IP 通信免遭窃听和篡改,可以有效抵御网络攻击,同时保持易用性。IPSec 有两个基本目标,分别是保护 IP 数据包安全和为抵御网络攻击提供防护措施。IPSec 结合密码保护服务、安全协议组和动态密钥管理三者来实现上述两个目标。

IPSec 是针对 IPv4 和 IPv6 的,其主要特征是可以支持 IP 级所有流量的加密和/或认证,增强所有分布式应用的安全性。IPSec 在 IP 层提供安全服务,使得系统可以选择所需要的安全协议,确定该服务所用的算法,并提供安全服务所需任何加密密钥。

IPSec 是一种基于端对端的安全模式。这种模式有一个基本前提假设,就是假定数据通信的传输媒介是不安全的。因此,通信数据必须经过加密,而掌握加解密方法的只有数据的发送端和接收端,两者各自负责相应的数据加解密处理,网络中其他只负责转发数据的路由器或计算机无须支持 IPSec。

9.3.4 单点登录技术

随着信息化的迅猛发展,用户每天需要登录到许多不同的信息系统,例如,邮件、数据库和各种应用服务器等。每个系统都要求用户遵循一定的安全策略,例如,要求输入用户名和口令等。随着用户需要登录系统的增多,出错的可能性就会增加,受到非法截获和破坏的可能性也会增大,安全性就会相应降低。而一旦用户忘记了口令,就不能执行任务,就需要请求管理员的帮助,在重新获得口令之前只能等待,造成系统和安全管理资源的开销,降低了生产效率。特别是新系统的涌现,在与现有系统的集成或融合上,尤其是针对相同的用户群,会带来以下问题:

(1) 如果每个系统都开发各自的身份认证系统,则将造成资源浪费,消耗开发成本,并延缓开发进度。

(2) 多个身份认证系统会增加整个系统的管理工作成本。

(3) 用户需要记忆多个账号和口令，使用极为不便。同时，由于用户口令遗忘而导致的支持费用不断上涨。

(4) 无法实现统一的认证和授权，多个身份认证系统使安全策略必须逐个在不同的系统内进行设置，因而造成修改策略的进度可能跟不上策略的变化；无法统一分析用户的应用行为。

因此，对于有多个业务系统应用需求的组织，需要配置一套统一的身份认证系统，以实现集中、统一的身份认证，并减少整个系统的成本。

1. 单点登录系统的概念

单点登录（Single Sign-On, SSO）技术是通过用户的一次性认证登录，即可获得需要访问系统和应用程序的授权，在此条件下，管理员不需要修改或干涉用户登录，就能方便地实现希望得到的安全控制。

单点登录系统采用基于数字证书的加密和数字签名技术，基于统一策略的用户身份认证和授权控制功能，对用户实行集中、统一的管理和身份认证，以区别不同的用户和信息访问者，并作为各应用系统的统一登录入口，同时，为通过身份认证的合法用户签发针对各个应用系统的登录票据（ticket），从而实现“一点登录，多点漫游”。必要时，单点登录系统能够与统一权限管理系统实现无缝结合，签发合法用户的权限票据，从而能够使合法用户进入其权限范围内的各应用系统，并完成符合其权限的操作。

2. SSO 系统的特征与功能

单点登录的实施可由 Kerberos 机制和外壳脚本机制来实现，也可以采用通用的安全服务 API 和分布式计算环境。一个理想的 SSO 产品应该具备以下特征和功能：

(1) 常规特征。支持多种系统、设备和接口。

(2) 终端用户管理灵活性。包括通常的账号创建、口令管理和用户识别。口令管理包括口令维护、历史记录和文法规则等；支持各种类型的令牌设备和生物学设备。

(3) 应用管理灵活性。若多个会话同时与一个公共主体相关，设备场景管理能保证其中一个会话发生改变，其他相关会话自动更新；能监控特定信息的使用；可将各种应用绑定在一起，来保证应用的一致性。

(4) 移动用户管理。保证用户在不同的地点对信息资源进行访问。

(5) 加密和认证。加密保证信息在终端用户和安全服务器之间传输时的安全性；认证保证用户的真实性。

(6) 访问控制。保证只有用户被授权访问的应用可以提供给用户。

(7) 可靠性和性能。包括 SSO 和其他访问控制程序之间的接口的可靠性和性能，以及接口的复杂度等。

3. Kerberos 机制

Kerberos 是一种网络身份认证协议，该协议的基础是基于信任第三方，它提供了在开放型网络中进行身份认证的方法，认证实体可以是用户也可以是用户服务。这种认证不依赖宿主机

的操作系统或计算机的 IP 地址，不需要保证网络上所有计算机的物理安全性，并且假定数据包在传输中可被随机窃取和篡改。

Kerberos 的安全机制在于首先对发出请求的用户进行身份验证，确认其是否是合法的用户；如是合法的用户，再审核该用户是否有权对其所请求的服务或计算机进行访问。从加密算法上来讲，其验证是建立在对称加密的基础上的，KDC 保存与所有密钥持有者通信的保密密钥，其认证过程颇为复杂。

4. 外壳脚本机制

外壳脚本机制通过原始认证进入系统外壳，然后外壳就会激发各种专用平台的脚本，来激活目标平台的账号和资源的访问。这种方式简化了用户的登录，但它没有提供同步的口令字以及其他管理方法。

9.4 系统访问控制技术

访问控制技术是系统安全防范和保护的主要核心策略，它的主要任务是保证系统资源不被非法使用和访问。访问控制规定了主体对客体访问的限制，并在身份识别的基础上，根据身份对提出资源访问的请求加以控制。

9.4.1 访问控制概述

访问控制是策略（policy）和机制（mechanism）的集合，它允许对限定资源的授权访问。访问控制技术也可以保护资源，防止那些无权访问资源的用户的恶意访问。访问控制是系统安全保障机制的核心内容，是实现数据保密性和完整性机制的主要手段，也是计算机系统中最重要和最基础的安全机制。

1. 访问控制的要素

访问控制包括三个要素，分别是主体、客体和控制策略。

（1）主体。主体是可以对其他实体施加动作的主动实体，有时也称为用户或访问者（被授权使用计算机的人员）。主体的含义是宽泛的，可以是用户所在的组织、用户本身，也可以是用户使用的计算机终端和手持终端（无线终端）等，甚至可以是应用服务程序或进程。

（2）客体。客体是接受其他实体访问的被动实体。客体的概念也很宽泛，凡是可以被操作的信息、资源和对象都可以认为是客体。在信息社会中，客体可以是信息、文件和记录等的集合体，也可以是网络上的硬件设施和无线通信中的终端等。

（3）控制策略。控制策略是主体对客体的操作行为集合约束条件集（访问规则集），直接定义了主体对客体的作用行为和客体对主体的条件约束。访问策略体现了一种授权行为，也就是客体对主体的权限允许，这种允许不超越规则集。

2. 访问控制的策略

访问控制策略包括登录访问控制、操作权限控制、目录安全控制、属性安全控制和服务器

安全控制等方面的内容。

(1) 登录访问控制策略。登录访问控制为系统访问提供了第一层访问控制，它控制哪些用户能够登录系统并获取资源，控制准许用户登录时间和具体工作站。用户的登录访问控制可分为三个步骤，分别是用户名的识别与验证、用户口令的识别与验证，以及用户账号的默认限制检查。三道关卡只要有一关未过，用户便不能登录系统。

(2) 操作权限控制策略。操作权限控制是针对可能出现的非法操作而采取的安全保护措施。用户和用户组被赋予一定的操作权限。系统管理员能够通过设置，指定用户和用户组可以访问系统中的哪些服务器和计算机，可以在服务器或计算机上操作哪些程序，访问哪些目录、子目录、文件和其他资源。系统管理员还可以根据访问权限将用户分为特殊用户、普通用户和审计用户，可以设定用户对能访问的文件、目录和设备执行的操作权限。

(3) 目录安全控制策略。系统应该允许管理员控制用户对目录、文件和设备的操作。目录安全允许用户在目录一级的操作对目录中的所有文件和子目录都有效。用户还可进一步自行设置对子目录和文件的权限。系统管理员应当为用户设置适当的操作权限，操作权限的有效组合可以让用户有效地完成工作，同时又能有效地控制用户对系统资源的访问。

(4) 属性安全控制策略。属性安全控制策略允许将设定的访问属性与服务器的文件、目录和设备联系起来。系统资源都应预先标出一组安全属性，用户对资源的操作权限对应一张访问控制表，属性安全控制级别高于用户操作权限设置级别。

(5) 服务器安全控制策略。系统允许在服务器控制台上执行一系列操作。用户通过控制台可以加载和卸载系统模块，可以安装和删除软件。系统应该提供服务器登录限制、非法访问者检测等功能。

9.4.2 访问控制模型

访问控制一般都是基于安全策略和安全模型的。访问控制模型是一种从访问控制的角度出发，描述系统安全，建立安全模型的方法。建立规范的访问控制模型，是实现严格访问控制策略所必需的。

1. Bell-LaPadula 模型

Bell-LaPadula (BLP) 模型是第一个正式的安全模型，该模型基于强制访问控制 (Mandatory Access Control, MAC) 系统，是典型的信息保密性多级安全模型，主要应用于军事系统中。在 BLP 模型中，数据和用户安全等级划分为公开、受限、秘密、机密和高密 5 个等级。

BLP 模型允许用户读取安全级别比它低的资源；相反地，写入对象的安全级别只能高于用户级别。BLP 模型基于两种规则来保障数据的机密度与敏感度，分别是上读和下写。上读是指主体不可读取安全级别高于它的数据，下写是指主体不可写入安全级别低于它的数据。例如，如果一个用户的安全级别为高密，想要访问安全级别为秘密的文件，他将能够成功读取该文件，但不能写入；而安全级别为秘密的用户访问安全级别为高密的文件，则会读取失败，但他能够写入。

2. Lattice 模型

在 Lattice 模型中，每个资源和用户都服从于一个安全类别。Lattice 模型通过划分安全边界

对 BLP 模型进行了扩充, 它将用户和资源进行分类, 并允许它们之间交换信息, 这是多边安全体系的基础。在执行访问控制功能时, Lattice 模型本质上与 BLP 模型是相同的, 而 Lattice 模型更注重形成“安全集束”。BLP 模型中的上读和下写原则在此仍然适用, 但前提条件必须是各对象位于相同的安全集束中。主体和客体位于不同的安全集束时, 不具有可比性, 它们之间没有信息可以流通。

3. Biba 模型

Biba 访问控制模型对数据提供了分级别的完整性保证, 类似于 BLP 保密性模型, Biba 模型也使用 MAC 系统。BLP 模型只解决了信息的保密问题, 它在完整性定义方面仍存在一定缺陷。BLP 模型没有采取有效的措施来制约对信息的非授权修改, 因此使非法和越权篡改成为可能。考虑到上述因素, Biba 模型模仿 BLP 模型的信息保密性级别, 定义了信息完整性级别, 在信息流向的定义方面不允许从级别低的进程流向级别高的进程, 也就是说, 用户只能向比自己安全级别低的客体写入信息, 从而防止非法用户创建安全级别高的客体信息, 避免越权和篡改等行为的发生。Biba 模型可同时针对有层次的安全级别和无层次的安全种类。

Biba 模型基于两种规则来保障数据的完整性与保密性, 分别是下读和上写。下读是指主体不能读取安全级别低于它的数据, 上写是指主体不能写入安全级别高于它的数据。从这两个属性来看, Biba 模型与 BLP 模型的两个属性是相反的, BLP 模型提供保密性, 而 Biba 模型对于数据的完整性提供保障。

9.4.3 访问控制分类

访问控制最早产生于 20 世纪 60 年代, 随后出现了多种重要的访问控制机制。访问控制因实现的基本理念不同, 分类也不同。常见的访问控制机制主要有自主访问控制 (Discretionary Access Control, DAC)、强制访问控制、基于角色的访问控制 (Role-Based Access Control, RBAC)、基于任务的访问控制 (Task-Based Access Control, TBAC) 和基于对象的访问控制 (Object-Based Access Control, OBAC) 等。

1. 自主访问控制

自主访问控制是目前计算机系统中实现最多的访问控制机制, 它是在确认主体身份以及它们所属组的基础上, 对访问进行限定的一种方法。传统的 DAC 最早出现在 20 世纪 70 年代初期的分时系统中, 它是多用户环境下最常用的一种访问控制技术, 在 UNIX 类操作系统中普遍采用。其基本思想是, 允许某个主体显式地指定其他主体对该主体所拥有的资源是否可以访问, 以及可执行的访问类型。

2. 强制访问控制

MAC 最早出现在 Multics 系统中, 在可信计算机系统评估标准 (Trusted Computer System Evaluation Criteria, TCSEC) 中被用作 B 级安全系统的主要评价标准之一。MAC 的基本思想是, 每个主体都有既定的安全属性, 每个客体也都有既定的安全属性, 主体对客体是否能执行特定的操作取决于两者安全属性之间的关系。通常, MAC 都要求主体对客体的访问满足 BLP 模型

的两个基本特性。

在实现上，MAC 和 DAC 通常为每个用户赋予对客体的访问权限规则集，考虑到管理的方便，在这一过程中，还经常将具有相同职能的用户聚为组，然后再为每个组分配许可权。用户自主地将自己所拥有的客体的访问权限授予其他用户的这种做法，其优点是显而易见的，但是，当企业的组织结构或系统的安全需求处于变化的过程中时，就需要进行大量烦琐的授权变动，系统管理员的工作将变得非常繁重，容易发生错误造成一些意想不到的安全漏洞。考虑到上述因素，必然会产生新的机制加以解决。

3. 基于角色的访问控制

基于角色的访问控制技术由于其对角色和层次化管理的引进，特别适用于用户数量庞大、系统功能不断扩展的大型系统。在 RBAC 中，在用户和访问许可权之间引入了角色的概念，用户与特定的一个或多个角色相联系，角色与一个或多个访问许可权相联系。

迄今为止，已发展了 4 种 RBAC 模型，其中基本模型（RBAC0）指明了用户、角色、访问权和会话之间的关系；层次模型（RBAC1）是偏序的，上层角色可继承下层角色的访问权；约束模型（RBAC2）除包含 RBAC0 的所有基本特性外，还增加了对 RBAC0 的所有元素的约束检查，只有拥有有效值的元素才可被接受；层次约束模型（RBAC3）兼有 RBAC1 和 RBAC2 的特点。

与 DAC 和 MAC 相比，RBAC 具有明显的优越性，RBAC 基于策略无关的特性，使它几乎可以描述任何安全策略，甚至 DAC 和 MAC 也可以用 RBAC 来描述。相比较而言，RBAC 是实施面向企业的安全策略的一种有效的访问控制方式，具有灵活性、方便性和安全性等特点，目前在大型 DBMS 的权限管理中得到普遍应用。

4. 基于任务的访问控制

基于任务的访问控制从应用和企业层角度来解决安全问题。它采用面向任务的观点，从任务的角度来建立安全模型和实现安全机制，在任务处理的过程中提供动态实时的安全管理。在 TBAC 中，对象的访问权限控制并不是静止不变的，而是随着执行任务的上下文环境发生变化，因此，TBAC 是一种动态安全模型。

TBAC 模型由 workflow、授权结构体、授权步和许可集 4 个部分组成。一个 workflow 的业务流程由多个任务构成，而一个任务对应于一个授权结构体，每个授权结构体由特定的授权步组成。授权结构体之间和授权步之间通过依赖关系联系在一起。在 TBAC 中，一个授权步的处理可以决定后续授权步对处理对象的操作许可。

通过授权步的动态权限管理，TBAC 支持最小特权原则和最小泄露原则，在执行任务时只给用户分配所需的权限，未执行任务或任务终止后用户不再拥有所分配的权限；在执行任务过程中，当某一权限不再使用时，授权步自动将该权限回收。TBAC 适用于 workflow、分布式处理、多点访问控制的信息处理和事务管理系统，最显著的应用是在安全 workflow 管理系统中。

5. 基于对象的访问控制

控制策略和控制规则是基于对象的访问控制的核心，在 OBAC 模型中，将 ACL 与受控对象及其属性相关联，并将访问控制选项设计成为用户、组或角色及其对应权限的集合。同时，

允许对策略和规则进行复用、继承和派生操作。这样,不仅可以对受控对象本身进行访问控制,受控对象的属性也可以进行访问控制,而且派生对象可以继承父对象的访问控制设置,这对于信息量巨大、信息内容更新变化频繁的管理信息系统非常有益,可以减轻由于信息资源的派生、演化和重组等带来的分配和设定角色权限等的工作量。

9.5 容灾与业务持续

灾难是指由于人为或自然的原因,造成信息系统严重故障或瘫痪,使信息系统支持的业务功能停顿或服务水平不可接受、达到特定的时间的突发性事件。当应用系统的一个完整环境因灾难性事件遭到破坏时,为了迅速恢复应用系统的数据和环境,使应用系统恢复运行,需要异地灾难备份系统,也称为容灾系统。

灾难备份是指为了灾难恢复而对数据、数据处理系统、网络系统、基础设施、技术支持能力和运行管理能力进行备份的过程。灾难备份与普通的数据备份的不同在于,它不仅备份系统中的数据,还备份系统中安装的应用程序、数据库系统、用户设置、系统参数等信息,以便在需要时迅速恢复整个系统。

9.5.1 灾难恢复技术

灾难恢复是指为了将信息系统从灾难造成的故障或瘫痪状态恢复到可正常运行状态,并将其支持的业务功能从灾难造成的不正常状态恢复到可接受状态,而设计的活动和流程。灾难恢复措施在整个备份制度中占有相当重要的地位。因为它关系到系统在经历灾难后能否迅速恢复。

1. 灾难恢复的技术指标

发生灾难时,对恢复工作所需的时间有一个清楚的认识是至关重要的,同样,了解现在的数据在恢复之后是什么样子的也同等重要。并非所有应用和数据都需要相同级别的可用性,灾难恢复的指标主要与容灾系统的数据恢复能力有关。

灾难恢复的两个关键概念是恢复点目标(Recovery Point Objective, RPO)和恢复时间目标(Recovery Time Objective, RTO)。RPO是指灾难发生后,容灾系统能将数据恢复到灾难发生前时间点的数据,它是衡量企业在灾难发生后会丢失多少数据的指标;RTO则是指灾难发生后,从系统宕机导致业务停顿时刻开始,到系统恢复至可以支持业务部门运作,业务恢复运营之时,此两点之间的时间。RPO可简单描述为企业能容忍的最大数据丢失量,RTO可简单描述为企业能容忍的恢复时间。

理想状态下,希望RTO为0,RPO为0,即灾难发生对企业生产毫无影响,既不会导致生产停顿,也不会导致生产数据丢失。但这显然不现实,企业要做的是尽量减少灾难造成的损失。企业在构建容灾备份系统时,首先要找到对企业自身而言比较适合的RTO目标,即在该目标定义下,用于灾难备份的投入应不大于对应的业务损失。

2. 灾难恢复等级

在《信息安全技术 信息系统灾难恢复规范》(GB/T 20988—2007)中,将灾难恢复划分为

6个等级。第1级为基本支持，第2级为备用场地支持，第3级为电子传输和部分设备支持，第4级为电子传输及完整设备支持，第5级为实时数据传输及完整设备支持，第6级为数据零丢失和远程集群支持。同时，该规范对灾难恢复能力等级评定原则和灾难备份中心的等级等也作了规范要求。

3. 容灾技术的分类

容灾系统的实现可以采用不同的技术，例如，既可以采用硬件进行远程数据复制，也可以采用软件实现远程的实时数据复制，并且实现远程监控和切换。容灾系统的归类要由其最终达到的效果来决定，从其对系统的保护程度来分，可以将容灾系统分为数据容灾和应用容灾，它们的高可用性级别逐渐提高。

数据容灾的关注点在于数据，即灾难发生后可以确保用户原有的数据不会丢失或遭到破坏。数据容灾较为基础，其中较低级别的数据容灾方案仅需利用磁带库和管理软件就能实现数据异地备份，达到容灾的功效；而较高级别的数据容灾方案则是依靠数据复制工具，例如卷复制软件，或者存储系统的硬件控制器，实现数据的远程复制。数据容灾是保障数据可用的最后底线，当数据丢失时能够保证应用系统可以重新得到所有数据。从这种意义上说，数据备份属于数据容灾的范畴。这种方案花费较低，构建简单，但灾难恢复时间较长，仍然存在风险，尽管用户原有数据没有丢失，但是应用会被中断，用户业务也将被迫停止。

对于业务应用繁多，并且系统需要保持7×24 h连续运行的企业来说，显然需要高级别的应用容灾来满足需求。应用容灾是在数据容灾的基础上，再将执行应用处理能力复制一份，也就是说，在备份站点同样构建一套应用系统。应用容灾系统能提供不间断的应用服务，让用户应用的服务请求能够透明地继续运行，而感受不到灾难发生，保证信息系统提供的服务完整、可靠和安全。一般来说，应用容灾系统需要通过更多软件来实现，它可以使企业的多种应用在灾难发生时进行快速切换，确保业务的连续性。

9.5.2 灾难恢复规划

信息系统的灾难恢复工作包括灾难恢复规划和灾难备份中心的日常运行，还包括灾难发生后的应急响应、关键业务功能在灾难备份中心的恢复和重续运行，以及主系统的灾后重建和回退工作。其中，灾难恢复规划是一个周而复始、持续改进的过程，包含灾难恢复需求的确定、灾难恢复策略的制定和实现，以及灾难恢复预案的制定、落实和管理。

1. 灾难恢复需求的确定

在确定灾难恢复需求时，主要进行风险分析、业务影响评估和确定灾难恢复目标三个方面的工作。

(1) 风险分析。标识信息系统的资产价值，识别信息系统面临的自然的和人为的威胁；识别信息系统的脆弱性，分析各种威胁发生的可能性，并定量或定性描述可能造成的损失。通过技术和管理手段，防范或控制信息系统的风险。依据防范或控制风险的可行性和残余风险的可接受程度，确定对风险的防范与控制措施。

(2) 业务影响评估。首先，分析业务功能和相关资源配置，对企业的各项业务功能及其之

间的相关性进行分析,确定支持各种业务功能的相应信息系统资源和其他资源,明确相关信息的保密性、完整性和可用性要求;其次,评估中断影响,采用定量和定性方法,对各种业务功能的中断造成的影响进行评估。

(3) 确定灾难恢复目标。根据风险分析和业务影响分析的结果,确定灾难恢复目标,包括关键业务功能及恢复的优先顺序、灾难恢复时间范围,即 RTO 和 RPO 的范围。

2. 灾难恢复策略的制定

支持灾难恢复各个等级所需的资源包括 7 个要素,分别是数据备份系统、备用数据处理系统、备用网络系统、备用基础设施、技术支持能力、运行维护管理能力和灾难恢复预案。按照灾难恢复资源的成本与风险可能造成的损失之间取得平衡的原则,确定每项关键业务功能的灾难恢复策略,不同的业务功能可采用不同的灾难恢复策略。灾难恢复策略包括灾难恢复资源的获取方式和灾难恢复等级各要素的具体要求。

3. 灾难恢复策略的实现

灾难恢复策略的实现包括灾难备份系统技术方案的实现、灾难备份中心的选择和建设、技术支持能力的实现、运行维护管理能力的实现和灾难恢复预案的实现。

(1) 灾难备份系统技术方案的实现。根据灾难恢复策略制定相应的灾难备份系统技术方案,包含数据备份系统、备用数据处理系统和备用的网络系统。技术方案中所涉及的系统,应获得与主系统相当的安全保护,且具有可扩展性。为确保技术方案满足灾难恢复策略的要求,应由相关部门对技术方案进行确认和验证,并记录和保存验证及确认的结果。按照确认的灾难备份系统技术方案进行开发,实现所要求的系统;按照经过确认的技术方案,灾难恢复规划实施组应制订各阶段的系统安装及测试计划,以及支持不同关键业务功能的系统安装及测试计划,并组织最终用户共同进行测试,确认各项功能可正确实现。

(2) 灾难备份中心的选择和建设。选择或建设灾难备份中心时,应根据风险分析的结果,避免灾难备份中心与主中心同时遭受同类风险。灾难备份中心还应具有方便灾难恢复人员或设备到达的交通条件,以及数据备份和灾难恢复所需的通信与电力等资源。灾难备份中心应根据资源共享、平战结合的原则,合理地布局。新建或选用灾难备份中心的基础设施时,计算机机房应符合有关国家标准的要求,工作辅助设施和生活设施应符合灾难恢复目标的要求。

(3) 技术支持能力的实现。企业应根据灾难恢复策略的要求,获取对灾难备份系统的技术支持能力。灾难备份中心应建立相应的技术支持组织,定期对技术支持人员进行技能培训。

(4) 运行维护管理能力的实现。为了达到灾难恢复目标,灾难备份中心应建立各种操作和管理制度,用以保证数据备份的及时性和有效性;备用数据处理系统和备用网络系统处于正常状态,并与主系统的参数保持一致;有效的应急响应和处理能力。

(5) 灾难恢复预案的实现。灾难恢复的每个等级均应按 GB/T 20988—2007 的具体要求制定相应的灾难恢复预案,并进行落实和管理。

4. 灾难恢复预案的制定、落实和管理

灾难恢复预案的制定过程如下:

(1) 起草。参照 GB/T 20988—2007 附录 B 的灾难恢复预案框架，按照风险分析和业务影响分析所确定的灾难恢复内容，根据灾难恢复等级的要求，结合企业其他相关的应急预案，撰写出灾难恢复预案的初稿。

(2) 评审。企业应对灾难恢复预案初稿的完整性、易用性、明确性、有效性和兼容性进行严格的评审。评审应有相应的流程保证。

(3) 测试。应预先制订测试计划，在计划中说明测试的案例。测试应包含基本单元测试、关联测试和整体测试。测试的整个过程应有详细的记录，并形成测试报告。

(4) 修订。根据评审和测试结果，对预案进行修订，纠正在初稿评审过程和测试中发现的问题和缺陷，形成预案的报批稿。

(5) 审核和批准。由灾难恢复领导小组对报批稿进行审核和批准，确定为预案的执行稿。

为了使相关人员了解信息系统灾难恢复的目标和流程，熟悉灾难恢复的操作规程，企业应组织灾难恢复预案的教育、培训和演练。

9.5.3 业务持续性规划

业务持续性规划（Business Continuity Planning, BCP）是在非计划的业务中断情况下，使业务继续或恢复其关键功能的一系列预定义的过程。BCP 可以帮助企业确认影响业务发展的关键性因素及其可能面临的威胁，由此而拟定的一系列计划与步骤可以确保企业无论处于何种状况下，这些关键因素的作用都能正常而持续地发挥。笼统地说，BCP 的目标就是确定并减少风险可能带来的损失，有效地保障业务的连续性。

1. 实施 BCP 的阶段

每个企业所制定的 BCP 都应该有企业或者所处行业独有的特色，彼此之间不会完全一致。但大致上说来，企业推动 BCP，需要经过 8 个主要阶段，分别为项目启动、风险评估与消减、业务影响分析、业务持续性策略、开发 BCP、人员培训与训练、测试与演练、BCP 的持续维护及变更管理。

2. BCP 主体框架

BCP 本身也应该看作是一个流程，企业范围内的 BCP 流程主体框架主要由 4 个部分组成，包括：灾难恢复规划（Disaster Recovery Planning, DRP）、业务恢复规划（Business Resumption Planning, BRP）、危机管理规划（Crisis Management Planning, CMP）和持续可用性（Continuous Availability, CA）。

为了衡量 BCP 流程，可以使用 BCP 平衡计分卡，内容包括价值综述、价值计划、BCP 风险度量标准、执行协议和有效方法。在平衡计分卡中，企业需要确定 BCP 流程的远景目标。远景目标的确定需要与企业管理和 BCP 流程基础设施的发展相协调。一旦确定了远景目标，BCP 流程规划人员就可以勾画出 BCP 流程改进中的关键成功因素，其中包括增长及改革、顾客满意度、员工情况、流程质量和财政情况等。

9.6 安全管理措施

目前,信息已成为人类的重要资产,由于计算机和网络技术的迅猛发展而带来的安全问题正变得日益突出,使得企业在业务运作过程中,面临巨大的信息资产泄露风险,信息基础设施也面临着大量存在于组织内外的各种威胁。因此,对信息系统需要加以严格管理和妥善维护,安全管理也随之产生。

安全管理是保护国家、组织和个人等各个层面上信息安全的重要基础。只有以有效的安全管理体系为基础,完善安全管理结构,综合应用安全管理策略和安全技术产品,才有可能建立起一个真正意义上的安全防护体系。安全管理应当涉及系统安全的各个方面,包括制定安全策略、风险评估、控制目标与方式选择、制定规范的操作流程、对人员进行安全培训等一系列工作。

9.6.1 安全管理的内容

安全管理体系是企业在整体或特定范围内建立的系统安全方针和目标,以及完善这些目标所采用的方法和手段所构成的体系,是安全管理活动的直接结果,可表示为策略、原则、目标、方法、程序和资源等总体集合。

1. 密码管理

为了保护计算机和信息系统中的敏感信息,有选择地采取技术上的和相关程序上的安全防护措施,是企业在安全管理体系中的迫切需求。使用基于密码机制的安全系统来保护敏感信息是行之有效的方法。被保护信息的机密性和完整性等安全特性由相应密码模块的功能来实现。因此,将密码模块置于系统中,以及相应的密码管理就显得尤为重要。

2. 网络管理

从功能上来看,网络管理一般包括配置管理、性能管理、安全管理、计费管理和故障管理等。由于网络安全对信息系统的性能、管理的关联和影响趋于更复杂、更严重,网络安全管理逐渐成为网络管理中的一个重要分支,正受到业界和用户的日益深切的广泛关注。

目前,在网络应用的深入和技术频繁升级的同时,非法访问、恶意攻击等安全威胁也在不断推陈出新,愈演愈烈。防火墙、VPN、IDS、防病毒、身份认证、数据加密、安全审计等安全防护和管理系统在网络中得到了广泛应用。虽然这些安全产品能够在特定方面发挥一定的作用,但是这些产品大部分功能分散,各自为战,形成了相互没有关联的、隔离的“安全孤岛”;各种安全产品彼此之间没有有效的统一管理调度机制,不能互相支撑、协同工作,从而使安全产品的应用效能无法得到充分发挥。比较理想的网络管理需要建立一个整体网络安全管理解决方案,以便总体配置和调控整个网络多层面、分布式的安全系统,实现对各种网络安全资源的集中监控、统一策略管理、智能审计和多种安全功能模块之间的互动,从而有效简化网络安全管理工作,提升网络的安全水平、可控制性和可管理性,降低用户的整体安全管理开销。

3. 设备管理

对设备的安全管理是保证信息系统安全的重要条件。设备安全管理包括设备的选型、检测、

安装、登记、使用、维护和存储管理等方面的内容。设备管理的不安全可能带来灾难性的后果。

为了保障信息系统的物理安全，对系统所在环境的安全保护，应遵守相关国家标准，例如，电子计算机机房设计规范、计算站场地技术条件、计算站场地安全要求等；网络设备、设施应配备相应的安全保障措施，包括防盗、防毁和防电磁干扰等，并定期或不定期地进行检查。

4. 人员管理

信息系统是由人来开发的，也是为人类服务的。影响信息系统安全的因素，除了少数难以预知和不可抗力的自然因素以外，绝大多数的安全威胁来自于人类自己。例如，对信息系统进行攻击和破坏的黑客和计算机病毒，以及操作失误等。因此，人始终是影响信息系统安全的最大因素，人员管理也就成为信息系统安全管理的关键。全面提高信息系统相关人员的技术水平、道德品质和安全意识等是信息系统安全的重要保证。

制定安全措施、标准、原则和实施过程，仅仅是有效的信息安全计划的开始。如果不能切实保证参与人员都能意识到自己的权利和责任，再强大的安全体系也是徒劳的。许多安全事件都是由内部人员引起的，因此，人员的素质和人员的管理是十分重要的。人员管理的核心是要确保有关业务人员的思想素质、职业道德和业务技能。

9.6.2 安全审计

安全审计是指由专业审计人员根据有关的法律法规、财产所有者的委托和管理当局的授权，对计算机网络环境下的有关活动或行为进行系统的、独立的检查验证，并作出相应评价。安全审计对主体访问和使用客体的情况进行记录和审查，以保证安全规则被正确执行，并帮助分析安全事故产生的原因。

安全审计是落实系统安全策略的重要机制和手段，通过安全审计，识别与防止系统内的攻击行为、追查系统内的泄密行为。它是系统安全保障系统中的一个重要组成部分。显然，安全审计作为一个专门的审计项目，要求审计人员必须具有较强的专业技术知识与技能。

1. 安全审计的基本要素

安全审计涉及4个基本要素，分别是控制目标、安全漏洞、控制措施和控制测试。

(1) 控制目标。控制目标是指企业根据具体的计算机应用，结合单位实际制定出的安全控制要求。

(2) 安全漏洞。安全漏洞是指系统的安全薄弱环节，容易被干扰或破坏的地方。

(3) 控制措施。控制措施是指企业为实现其安全控制目标所制定的安全控制技术、配置方法及各种规范制度。

(4) 控制测试。控制测试是将企业的各种安全控制措施与预定的安全标准进行一致性比较，确定各项控制措施是否存在、是否得到执行、对漏洞的防范是否有效，评价企业安全措施的可依赖程度。

2. CC 标准

由ISO提出的通用准则(Common Criteria, CC)将安全审计功能分为6个部分，分别是安

全审计自动响应、安全审计数据生成、安全审计分析、安全审计浏览、安全审计事件选择和安全审计事件存储。

(1) 安全审计自动响应。定义在被测事件指示出一个潜在的安全攻击时做出的响应，它是管理审计事件的需要，这些需要包括报警或行动。

(2) 安全审计数据生成。记录与安全相关的事件的出现，包括鉴别审计层次、列举可被审计的事件类型，以及鉴别由各种审计记录类型提供的相关审计信息的最小集合。系统可定义可审计事件清单，每个可审计事件对应于某个事件级别。

(3) 安全审计分析。定义了分析系统活动和审计数据来寻找可能的或真正的安全违规操作。它可以用于入侵检测或对安全违规的自动响应。当一个审计事件集出现或累计出现一定次数时，可以确定一个违规的发生，并执行审计分析。事件的集合能够由经授权的用户进行增加、修改或删除等操作。审计分析分为潜在攻击分析、基于模板的异常检测、简单攻击试探和复杂攻击试探等几种类型。

(4) 安全审计浏览。审计系统能够使授权的用户有效地浏览审计数据，它包括审计浏览、有限审计浏览和可选审计浏览。

(5) 安全审计事件选择。系统管理员能够维护、检查或修改审计事件的集合，能够选择对哪些安全属性进行审计。例如，与目标标识、用户标识、主体标识、主机标识或事件类型有关的属性，系统管理员将能够有选择地在个人识别的基础上审计任何一个用户或多个用户的动作。

(6) 安全审计事件存储。审计系统将提供控制措施，以防止由于资源的不可用丢失审计数据；能够创造、维护、访问它所保护的对象的审计踪迹，并保护其不被修改、非授权访问或破坏。

9.6.3 私有信息保护

在现实世界中，个人信息随处可见，与生活息息相关。私有信息是个人隐私的一部分，应征得信息的主体同意，才可在限定的目的和范围内使用。目前，由于我国还没有保护私有信息的法律，公民和社会普遍缺乏私有信息保护意识，私有信息一度被不合理地公开甚至滥用。例如，Internet 上盛行的“人肉搜索”就是一个典型的例子。

同时，随着国际交流的增加和国际业务的增多，私有信息保护已成为国际业务交流中一项重要的制衡条件。随着经济的高速发展和网络技术的不断进步，私有信息的不当使用、滥用造成的隐患日益严重。

在信息社会，私有信息的收集、处理、利用及传递，在大多数情况下均离不开信息技术。因此，私有信息的保护还应当考虑通过技术措施（例如，加密技术等）得以实现。另外，人们在使用网络时，也需要进行相应的设置，防止私有信息的暴露和被非法使用。

9.7 系统可靠性

系统可靠性是系统在规定的时间内及规定的环境条件下，完成规定功能的能力，也就是系统无故障运行的概率。根据国家标准《系统与软件工程 系统与软件质量要求和评价

《SQuaRE》第10部分：系统与软件质量模型》（GB/T 25000.10—2016）的规定，系统可靠性包括成熟性、容错性、易恢复性和可靠性的依从性4个子特性。其中，成熟性是指系统避免因错误的发生而导致失效的能力；容错性是指在系统发生故障或违反指定接口的情况下，系统维持规定的性能级别的能力；易恢复性是指在系统发生失效的情况下，重建规定的性能级别并恢复受直接影响的数据的能力；可靠性的依从性是指系统依附于与可靠性相关的标准、约定或规定的能力。

9.7.1 系统故障模型

系统故障是指由于部件的失效、环境的物理干扰、操作错误或不正确的设计所引起的硬件或软件中的错误（或差错）状态，其中错误是指故障在系统中的具体位置。在信息系统中，故障或错误有如下几种表现形式：

（1）永久性。永久性是指连续稳定的失效、故障或错误。在计算机硬件中，永久性失效反映了不可恢复的物理改变。

（2）间歇性。间歇性是指那些由于不稳定的硬件或软件状态所引起的、仅仅是偶然出现的故障或错误。

（3）瞬时性。瞬时性是指那些由于暂时环境条件而引起的故障或错误。

一个故障可能由物理器件失效、错误的系统设计、环境条件变化或用户的错误操作所引起。永久性失效会导致永久性故障。间歇性故障可能由不稳定、临界稳定或不正确的设计所引起。环境条件变化会造成瞬时性故障。所有这些故障都可能引起系统错误。不正确的设计和用户失误会直接引起错误。由硬件的物理条件、不正确的软硬件设计，或不稳定但重复出现的环境条件所引起的故障可能是可检测的，并且可以通过替换或重新设计来修复；然而，由于暂时环境条件所引起的故障是不能修复的，因为其硬件本身实际上并没有损坏。瞬时和间歇故障已经成为系统中的一个主要错误源。

故障的表现形式千差万别，可以利用故障模型对千差万别的故障表现进行抽象。故障模型可以在系统的各个级别上建立。一般来说，故障模型建立的级别越低，进行故障处理的代价也就越低，但故障模型覆盖的故障也就越少。

1. 逻辑级的故障

逻辑级的故障是指硬件逻辑上出现的故障，一般是指电路中元器件的输入或输出固定为0（或1）。例如，某线接地、电源短路或元件失效等都可能造成逻辑级的故障。逻辑级的故障又可分为短路故障、开路故障和桥接故障。短路故障是指一个元件的输出线的逻辑值恒等于输入线的逻辑值；开路故障是指元件的输出线悬空，逻辑值可根据具体电路来决定；桥接故障是指两条不应相连的线连接在一起而发生的故障。

2. 数据结构级的故障

故障在数据结构上的表现称为差错。常见的差错有以下三种：

（1）独立差错。一个故障的影响表现为使一个二进制位发生改变。

（2）算术差错。一个故障的影响表现为使一个数据的值增加或减少 $2^i (i=0,1,2,\dots)$ 。

(3) 单向差错。一个故障的影响表现为使一个二进制向量中的某些位朝一个方向(0或1)改变。

3. 软件故障和软件差错

软件故障是指软件设计过程造成的与设计说明的不一致,软件故障在数据结构或程序输出中的表现称为软件差错。与硬件不同,软件不会因为环境应力而疲劳,也不会因为时间的推移而衰老。因此,软件故障只与设计有关。常见的软件差错有以下几种:

- (1) 非法转移:程序执行了说明中不存在的转移。
- (2) 误转移:程序执行了尽管说明中存在,但依据当前控制数据不应进行的转移。
- (3) 死循环:程序执行时间超过了规定界限。
- (4) 空间溢出:程序使用的空间超过了规定的界限。
- (5) 数据执行:指令计数器指向数据单元。
- (6) 无理数据:程序输出的数据不合理。

4. 系统级的故障

故障在系统级上的表现为功能错误,即系统输出与系统设计说明的不一致。如果系统输出无故障保护机构,则故障在系统级上的表现就会造成系统失效。

9.7.2 系统可靠性指标

系统可靠性可以通过历史数据和开发数据直接测量和估算出来,与之相关的概念主要有平均无故障时间、平均故障修复时间、平均故障间隔时间和系统可用性等。

1. 平均无故障时间

产品在规定的条件下和规定的时间内,完成规定功能的能力称为可靠性。可靠性的概率度量叫可靠度,使用 $R(t)$ 表示。可靠度为 $R(t)$ 的系统的平均无故障时间(Mean Time To Failure, MTTF)定义为从 $t=0$ 时到故障发生时系统的持续运行时间的期望值,计算公式如下:

$$\text{MTTF} = \int_0^{\infty} R(t) dt$$

如果 $R(t) = e^{-\lambda t}$,则 $\text{MTTF} = 1/\lambda$ 。 λ 为失效率,是指系统在单位时间内发生失效的预期次数,在此处假设为常数。

例如,假设同一型号的1000台计算机,在规定的条件下工作1000h,其中有10台出现故障。每台计算机千小时的可靠度 $R(t)$ 为 $(1000-10)/1000=0.99$,失效率 λ 为 $10/(1000 \times 1000)=1 \times 10^{-5}$, $\text{MTTF}=1/(1 \times 10^{-5})=10^5 \text{ h}$ 。

2. 平均故障修复时间

可用度为 $A(t)$ 的系统的平均故障修复时间(Mean Time To Repair, MTTR)可以用类似于求MTTF的方法求得。设 $A_1(t)$ 是在风险函数 $Z(t)=0$ 且系统的初始状态为1的条件下 $A(t)$ 的特殊情况,则

$$MTTR = \int_0^{\infty} A_1(t) dt$$

此处假设修复率 $\mu(t) = \mu$ (常数), 修复率是指单位时间内可修复系统的平均次数, 则

$$MTTR = 1/\mu$$

3. 平均故障间隔时间

因为两次故障之间必然有修复行为, 因此, 平均故障间隔时间 (Mean Time Between Failures, MTBF) 中应包含 MTTR。对于可靠度服从指数分布的系统, 从任意时刻 t_0 到达故障的期望时间都是相等的, 因此有

$$MTBF = MTTR + MTTF$$

在实际应用中, 一般 MTTR 的值很小, 所以通常认为 $MTBF \approx MTTF$ 。

4. 系统可用性

系统可用性是指在某个给定时间点上系统能够按照需求执行的概率, 其公式为:

$$\text{系统可用性} = MTTF / (MTTR + MTTF) \times 100\% = MTTF / MTBF \times 100\%$$

9.7.3 系统可靠性模型

与系统故障模型对应的就是系统可靠性模型, 常用的可靠性模型主要有时间模型、故障植入模型和数据模型。

1. 时间模型

时间模型基于这样一个假设: 系统中的故障数目在 $t=0$ 时是常数, 随着故障被纠正, 故障数目逐渐减少。在此假设下, 系统经过一段时间的调试后剩余故障的数目可用下列公式来估计:

$$E_r(\tau) = \frac{E_0}{I - E_c(\tau)}$$

其中, τ 为调试时间, $E_r(\tau)$ 为系统在时刻 τ 剩余的故障数, E_0 为 $\tau=0$ 时系统中的故障数, $E_c(\tau)$ 为在 $[0, \tau]$ 内纠正的故障数, I 为系统中的指令数。

由故障数 $E_r(\tau)$ 可以得出系统的风险函数 $Z(t) = C \cdot E_r(\tau)$, 其中 C 是比例常数。于是, 系统的可靠度为:

$$R(t) = e^{-\int_0^t z(t) dt} = e^{-C(E_0 / (I - E_c(\tau)))}$$

系统的平均无故障时间为:

$$MTTF = \int_0^{\infty} R(t) dt = \frac{1}{C(E_0 / (I - E_c(\tau)))} = \frac{I - E_c(\tau)}{CE_0}$$

在时间模型中, 需要确定在调试前系统中的故障数目, 而这往往是一项相当困难的任务。

2. 故障植入模型

故障植入模型是一个面向错误数的数学模型,其目的是以系统中的错误数作为衡量可靠性的标准。故障植入模型的基本假设如下:

- (1) 系统中的固有错误数是一个未知的常数。
- (2) 系统中的人为错误数按均匀分布随机植入。
- (3) 系统中的固有错误数和人为错误被检测到的概率相同。
- (4) 检测到的错误立即改正。

用 N_0 表示固有错误数, m 表示植入的错误数, n 表示检测到的错误数,其中检测到的植入错误数为 k ,用最大似然法求解可得固有错误数 N_0 的点估计值为:

$$\hat{N}_0 = \left\lceil \frac{m \times (n - k)}{k} \right\rceil$$

考虑到实施植入错误时遇到的困难,有关专家又提出了两步查错法。该方法是由两组测试人员独立对系统进行测试,检测到的错误立即改正。用 N_0 表示系统中的固有错误数, m 表示第一组测试人员发现的错误数, n 表示第二组测试人员发现的错误数,如果两组测试人员发现的相同错误数为 k ,则系统固有错误数 N_0 的点估计值为:

$$\hat{N}_0 = \left\lceil \frac{m \times n}{k} \right\rceil$$

3. 数据模型

在数据模型下,对于一个预先确定的输入环境,系统的可靠度定义为在 n 次连续运行中系统完成指定任务的概率。其基本方法如下:

设 SRS 所规定的功能为 F ,而系统实现的功能为 F' ,预先确定的输入集为 $E = \{e_i | i = 1, 2, \dots, n\}$,令导致系统差错的所有输入的集合为 E_e ,即

$$E_e = \{e_j | e_j \in E \text{ and } F'(e_j) \neq F(e_j)\}$$

则系统运行一次出现差错的概率为:

$$P_1 = \frac{|E_e|}{|E|}$$

也就是说,系统一次运行正常的概率为 $R_1 = 1 - P_1$ 。

在上述讨论中,假设所有输入出现的概率相等。如果不相等,且 e_i 出现的概率为 $p_i (i = 1, 2, \dots, n)$,则系统运行一次出现差错的概率为:

$$P_1 = \sum_{i=1}^n (Y_i \cdot p_i)$$

其中:

$$Y_i = \begin{cases} 0, & F'(e_i) = F(e_i) \\ 1, & F'(e_i) \neq F(e_i) \end{cases}$$

于是,系统的可靠度(n 次运行不出现差错的概率)为:

$$R(n) = R_1^n = (1 - P_1)^n$$

显然,只要知道每次运行的时间,上述数据模型中的 $R(n)$ 就很容易转换成时间模型中的 $R(t)$ 。

9.7.4 系统可靠性分析

计算机系统是一个复杂的系统,而且影响其可靠性的因素也非常多,很难直接对其进行可靠性分析。但通过建立适当的数学模型,把大系统分割成若干子系统,则可以简化其分析过程。组合模型是分析系统可靠性最常用的方法。一个系统只要满足以下4个条件,就可以用组合模型来计算其可靠性:

- (1) 系统只有两种状态:运行状态和失效状态。
- (2) 系统可以划分成若干个不重叠的子系统(部件),每个子系统也只有运行和失效两种状态。
- (3) 子系统的失效是独立的。
- (4) 系统的状态只依赖于子系统的状态。当且仅当系统中的剩余资源不满足系统运行的最低资源要求时系统失效。

1. 串联系统

假设一个系统由 n 个子系统组成,当且仅当所有的子系统都能正常工作时,系统才能正常工作,这种系统称为串联系统,如图9-5所示。



图 9-5 串联系统

如果系统的各个子系统的可靠度分别用 $R_1, R_2, \dots, R_n$ 表示,则系统的可靠度为:

$$R = R_1 \times R_2 \times \dots \times R_n$$

如果系统的各个子系统的失效率分别用 $\lambda_1, \lambda_2, \dots, \lambda_n$ 来表示,则系统的失效率为:

$$\lambda = \lambda_1 + \lambda_2 + \dots + \lambda_n$$

要注意的是,此处只给出了直接计算结果,省略了计算公式的数学推导过程。另外,失效率的计算公式只是一个近似公式,当各子系统的失效率很低(接近0)时才是正确的。当已知系统的可靠度为 R 时,则可通过 $\lambda = 1 - R$ 求得系统的失效率。

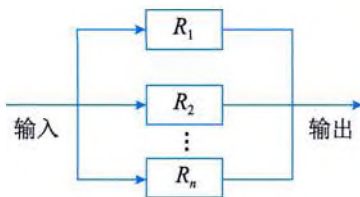


图 9-6 并联系统

2. 并联系统

假如一个系统由 n 个子系统组成,只要有一个子系统能够正常工作,系统就能正常工作,这种系统称为并联系统,如图9-6所示。

如果系统的各个子系统的可靠度分别用 $R_1, R_2, \dots, R_n$ 表示, 则系统的可靠度为:

$$R = 1 - (1 - R_1) \times (1 - R_2) \times \dots \times (1 - R_n)$$

如果所有子系统的失效率均为 λ , 则系统的失效率为:

$$\mu = \frac{1}{\frac{1}{\lambda} \sum_{j=1}^n \frac{1}{j}}$$

在并联系统中, 只有一个子系统是真正需要的, 其余 $n-1$ 个子系统称为冗余子系统。随着冗余子系统数量的增加, 系统的平均无故障时间也就增加了。

3. 模冗余系统

模冗余系统由 m ($m=2n+1, n>1$) 个相同的子系统和一个表决器组成, 经过表决器表决后, m 个子系统中占多数相同结果的输出作为系统的输出, 如图 9-7 所示。

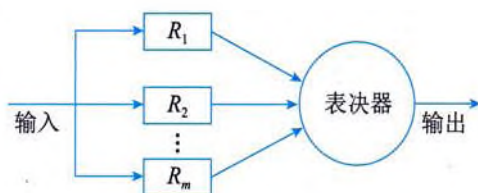


图 9-7 模冗余系统

在 m 个子系统中, 只有 $n+1$ 个或 $n+1$ 个以上子系统能正常工作时, 系统就能正常工作, 输出正确结果。假设表决器是完全可靠的, 每个子系统的可靠度为 R_0 , 则 m 模冗余系统的可靠度为:

$$R = \sum_{i=n+1}^m C_m^i \times R_0^i (1 - R_0)^{m-i}$$

其中, C_m^j 为从 m 个元素中取 j 个元素的组合数。

在实际应用中, 信息系统往往是多种结构的混联系统。例如, 某高可靠性计算机系统由图 9-8 所示的冗余部件构成。



图 9-8 某计算机系统

显然, 该系统为一个串并联综合系统, 可以先计算出中间 2 个并联系统的可靠度。根据并联公式 $R = 1 - (1 - R_1) \times (1 - R_2) \times \dots \times (1 - R_n)$, 可得到 3 个部件并联的可靠度为 $1 - (1 - R)^3$, 2 个部件并联的可靠度为 $1 - (1 - R)^2$ 。然后, 再根据串联公式 $R = R_1 \times R_2 \times \dots \times R_n$, 可得到整个系统的可靠度为 $R \times (1 - (1 - R)^3) \times (1 - (1 - R)^2) \times R$ 。

9.8 冗余技术

提高系统可靠性的技术可以分为避错（排错）技术和容错技术。避错是通过技术评审、系

统测试和正确性证明等技术，在系统正式运行之前避免、发现和改正错误。然而，随着系统规模越来越大，结构越来越复杂，以及避错技术自身存在的复杂性和局限性，避错已远远不能保证系统的可靠性；另一方面，随着信息系统应用进入一些高可靠性要求的领域，对系统可靠性的要求也越来越高，因此，容错成为提高系统可靠性的重要手段。容错是指系统在运行过程中发生一定的硬件故障或软件错误时，仍能保持正常工作而不影响正确结果的一种性能或措施。容错技术主要是采用冗余方法来消除故障的影响。

9.8.1 冗余技术的分类

冗余是指在正常系统运行所需的基础上加上一定数量的资源，包括信息、时间、硬件和软件。冗余是容错技术的基础，通过冗余资源的加入，可以使系统的可靠性得到较大的提高。主要的冗余技术有结构冗余（硬件冗余和软件冗余）、信息冗余、时间冗余和冗余附加4种。

1. 结构冗余

结构冗余是常用的冗余技术，按其工作方式，可分为静态冗余、动态冗余和混合冗余三种。

（1）静态冗余。静态冗余又称为屏蔽冗余或被动冗余，常用的有三模冗余和多模冗余。静态冗余通过表决和比较来屏蔽系统中出现的错误。

（2）动态冗余。动态冗余又称为主动冗余，它是通过故障检测、故障定位及故障恢复等手段达到容错的目的。其主要方式是多重模块待机储备，当系统检测到某工作模块出现错误时，就用一个备用的模块来顶替它并重新运行。各备用模块在其待机时，可与主模块一样工作，也可不工作。

（3）混合冗余。混合冗余技术是将静态冗余和动态冗余结合起来，且取二者之长处。它先使用静态冗余中的故障屏蔽技术，使系统免受某些可以被屏蔽的故障的影响。而对那些无法屏蔽的故障则采用主动冗余中的故障检测、故障定位和故障恢复等技术，并且对系统可以作重新配置。因此，混合冗余的效果要大大优于静态冗余和动态冗余。然而，由于混合冗余既要有静态冗余的屏蔽功能，又要有动态冗余的各种检测和定位等功能，它的附加硬件的开销相当大，所以混合冗余的成本很高，仅在对可靠性要求极高的场合中采用。

2. 信息冗余

信息冗余是在实现正常功能所需要的信息外，再添加一些信息，以保证运行结果正确性的方法。例如，检错码和纠错码就是信息冗余的例子。这种冗余信息的添加方法是按照一组预定的规则进行的。符合添加规则而形成的带有冗余信息的字称为码字，而那些虽带有冗余信息但不符合添加规则的字则称为非码字。当系统出现故障时，可能会将码字变成非码字，于是在译码过程中会将引起非码字的故障检测出来，这就是检错码的基本思想。纠错码则不仅可以将错误检测出来，还能将由故障引起的非码字纠正成正确的码字。

由此可见，信息冗余的主要任务在于研究出一套理想的编码和译码技术来提高信息冗余的效率。编码技术中应用最广泛的是奇偶校验码、海明校验码和循环冗余校验码。

3. 时间冗余

时间冗余是以时间（即降低系统运行速度）为代价来减少硬件冗余和信息冗余的开销，以

达到提高可靠性的目的。在某些实际应用中,硬件冗余和信息冗余的成本、体积、功耗、重量等开销可能过高,而时间并不是太重要的因素时,可以使用时间冗余技术。时间冗余的基本概念是重复多次进行相同的计算,称为重复执行(简称复执),以达到故障检测的目的。

4. 冗余附加

冗余附加是指为实现上述冗余技术所需的资源和技术,包括程序、指令、数据,以及存放和调用它们的空间等。

9.8.2 冗余系统

在实际应用中,各种冗余技术经常是结合起来使用的。将各种冗余技术融合在一个系统中,就称之为冗余系统。一般来说,一个较为完整的冗余系统,在处理运行中出现的故障时,大致有以下10个步骤:

(1) 故障检测。故障检测一般可分为两类:联机检测和脱机检测。前者提供了实时检测的能力,这种检测工作与系统的正常工作同时进行;后者在进行检测时,系统必须停止正常工作。

(2) 故障屏蔽。这与故障检测正好相反,它不是将故障检测出来,而是将出现的故障屏蔽起来,使系统不受故障的影响。

(3) 故障限制。限制故障影响的范围,防止已发生的故障影响到系统的其他部分。

(4) 复执。这是一种检测瞬时性故障的有效措施,它可以提高系统抗瞬时性故障干扰的能力。

(5) 故障诊断。在故障检测的基础上,对故障进行定位。这对以后的修复、重配置等过程有很重要的意义。

(6) 系统重配置。若故障一旦被检出并定位,系统应有能力将发生故障的子系统替换下来,或将故障子系统与其他子系统隔离开。当故障子系统被替换下来后,系统仍应能保持正常运行,只是系统运行速度下降、功能减弱。这一现象称为系统降级使用。

(7) 系统恢复。当检测出故障,必要时在系统重配置后即可消除故障引发的差错。这时,系统应能返回到出现故障断点前的环境继续运行。故障的恢复策略一般有两种,分别是前向恢复和后向恢复。

(8) 系统重新启动。如果系统由于出现过多的故障而造成大量的错误,以至于破坏了许多信息无法恢复时,就不能再使用上述系统恢复办法,而必须重新启动。重新启动可分为热启动和冷启动。前者是在部分信息遭到破坏但还有一部分可以利用的情况时使用,后者则是在几乎所有信息均遭破坏的情况下使用。

(9) 修复。凡是已确定有故障的子系统必须进行修复。修复可分为脱机修复和联机修复两种。若要修复的子系统卸下后对系统影响不大,或者修复这些子系统时系统必定会停机,就使用脱机修复。联机修复是指系统能自动启用备份子系统替代有故障的子系统,并保持系统继续运行,然后再修复切换下来的故障子系统。

(10) 系统重组。当上述各步骤完成后,系统必须重新组合,以便完全恢复正常运行。

9.9 软件容错技术

软件容错的基本思想是从硬件容错引申而来，利用软件设计的冗余和多样化来达到屏蔽错误的影响，提高系统可靠性的目的。软件容错的主要方法是提供足够的冗余信息和算法程序，使系统在实际运行时能够及时发现程序设计错误，采取补救措施，以提高系统可靠性，保证整个系统的正常运行。

软件容错技术主要有N版本程序设计、恢复块方法和防卫式程序设计等。除上述3种方法外，提高软件容错能力也可以从计算机平台环境、软件工程和构造异常处理模块等不同方面达到。此外，利用高级程序设计语言本身的容错能力，采取相应的策略，也是可行的办法。例如，C++语言中的try_except处理法和try_finally中止法等。

9.9.1 N版本程序设计

N版本程序设计是一种静态的故障屏蔽技术，采用前向恢复的策略，如图9-9所示。

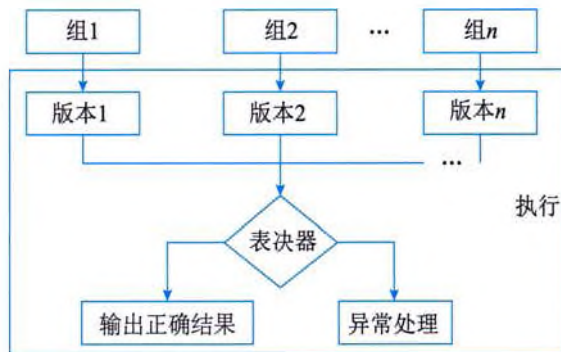


图 9-9 N 版本程序设计

N版本程序的设计思想是用 n 个具有相同功能的程序同时执行一项计算，结果通过多数表决来选择。其中 n 个版本的程序必须由不同的人（小组）独立设计，使用不同的方法、不同的设计语言、不同的开发环境和工具来实现，目的是减少 n 个版本的程序在表决点上相关错误的概率。

1. 与通常软件开发过程的区别

与通常软件开发过程不同的是，N版本程序设计增加了三个新的阶段，分别是相异成分规范评审、相异性确认和背对背测试。

（1）相异成分规范评审。每个版本的工作组均接收到一份相同的SRS。为了保证相异性，这些工作组之间不允许进行任何形式的交流，有关SRS的问题只能在工作组和项目管理人员之间进行交换，这种交换是通过问题单的形式进行的。对于各工作组提出的问题，由项目管理人员组成的SRS评审委员会对每个问题单进行研究。若是对SRS理解不正确，则向有关工作组进行解释；若是SRS本身的问题，则修改SRS，并通知所有工作组。

（2）相异性确认。相异性确认在相异成分详细设计后进行，其目的是对相异性进行评估。

（3）背对背测试。使用同样的测试数据对N版本程序进行测试，将 n 个版本程序的运行结

果进行比较,用以发现版本中的软件故障。

2. 其他需要注意的问题

与通常的软件开发相比,除了开发过程不同之外,N版本程序设计还需要注意以下问题:

(1) N版本程序的同步。由于各种不同版本并行执行,有时甚至在不同的计算机中执行,必须解决彼此之间的同步问题。N版本程序的同步机制除通常的帧同步之外,还有事件同步机制,以保证输入一致性和交叉检查点的正常工作。在N版本程序的同步机制中,需要引入超时处理,以解决失步问题。

(2) N版本程序之间的通信。由于N版本程序设计的独立性,不同版本的数据表示可能是不同的,因此,在 n 个版本程序之间进行数据通信时,必须进行数据变换。可将 n 个版本通信接口处的数据规定为一种独立于各个版本的统一的数据格式,任一版本发送数据时,需将该版本的内部数据表示转换为统一的数据表示;当任一版本接收其他版本的数据时,需将统一的数据表示转换为内部所需的数据表示。

(3) 表决算法。在N版本程序设计中,通常有三种表决算法:全等表决(主要适用于布尔量的表决)、非精确表决(允许设置一个偏差,主要适用于数值量的表决)和Cosmetie表决(适用于字符串的表决)。

(4) 一致比较问题。在进行有限精度运算的情况下,计算的结果与所使用的特定算法和计算的顺序有关,在进行计算量比较时(例如,将某计算量与一个常量进行比较),虽然这些计算量能满足SRS要求,但比较结果可以全然不同,最终导致在N版本表决时不能得出正确的结果。对于这个问题,比较好的解决方法是将需要进行比较的计算量进行一次交叉表决,其缺点是降低了N版本程序的相异性,并使系统的实时性变差。

(5) 数据相异性。软件的故障往往仅在数据空间的个别点发生,当对这些个别点进行修正后,软件仍可正常工作。这是由于实际情况对数据空间的任一点,往往允许有一定的误差,只要数据点在允许的误差范围内,则可看作是逻辑上等效的。因此,当软件在某个输入数据 x 上存在故障,输出不正确时,可选用适当的数据重新表示算法,计算出与 x 逻辑等效的输入数据 y ,然后对 y 进行计算,从而得到正确的输出。

9.9.2 恢复块方法

恢复块方法是一种动态的故障屏蔽技术,采用后向恢复策略,如图9-10所示。

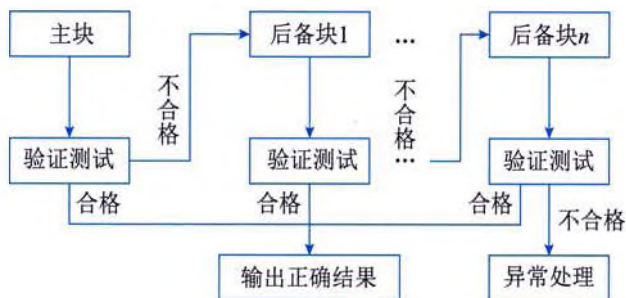


图9-10 恢复块方法

恢复块方法提供具有相同功能的主块和几个后备块，一个块就是一个执行完整的程序段，主块首先投入运行，结束后进行验证测试，如果没有通过验证测试，系统经现场恢复后由后备块1运行。后备块1运行结束后也进行验证测试，如果没有通过验证测试，系统经现场恢复后由后备块2运行。重复这一过程，可以重复到耗尽所有的后备块，或者某个程序故障行为超出了预料，从而导致不可恢复的后果。

在程序设计时，应保证实现主块和后备块之间的独立性，避免相关错误的产生，使主块和后备块之间的共性错误降到最低程度。

1. 验证测试

恢复块方法依赖于一个裁决者，那就是验证测试（可接受测试），由它来决定同一算法不同实现的计算结果是否正确。带有恢复块的系统被分成故障可恢复的块。整个系统就由这些容错块组成。每一块包含至少一个一级模块、一个二级模块和一个例外处理模块，以及一个验证测试模块。验证测试模块完成故障检测功能，它本身的故障对恢复块方法而言是共性的，因此，必须确保它的正确性。同时，验证测试模块是为了确定模块计算结果的正确性，它必须尽可能的简单。

2. 与 N 版本程序设计的比较

恢复块方法与 N 版本程序设计的比较如表 9-3 所示。

表 9-3 恢复块方法与 N 版本程序设计的比较

比较项目	恢复块方法	N 版本程序设计
硬件运行环境	单机	多机
错误检测方法	验证测试程序	表决
恢复策略	后向恢复	前向恢复
实时性	差	好

9.9.3 防卫式程序设计

N 版本程序设计和恢复块方法都是基于设计冗余的思想，这给程序员和处理机都增加了许多工作，而且它们的结构本身又带来了一些问题和困难，例如，多版本程序设计中的相关性错误问题和恢复块方法中的验证测试的设计等。

防卫式程序设计是一种不采用任何传统的容错技术就能实现软件容错的方法，对于程序中存在的错误和不一致性，防卫式程序设计的基本思想是通过在程序中包含错误检查代码和错误恢复代码，使得一旦发生错误，程序就能撤销错误状态，恢复到一个已知的正确状态中去。其实现策略包括错误检测、破坏估计和错误恢复三个方面。

1. 错误检测

在程序中插入状态断言，所谓状态断言，就是包含状态变量的逻辑谓词。这些断言可插入到一些重要的赋值语句之前，使得那些可能导致错误的赋值在变量状态发生变化之前被检测出来。例如，实型变量 Grade 表示一个学生的成绩，C 为一个整型变量，那么，可以在赋值语句

“Grade=C”之前插入断言“ $\{C \geq 0.0 \text{ and } C \leq 100.0\}$ ”，以保证对 Grade 赋值的正确性。

插入断言法主要适用于抽象数据类型，因为在抽象数据类型中，断言检查代码只需定义一次，就可对该类型变量的操作进行检查。在程序中普遍采用状态断言检查将占用大量空间，折中的办法是在重要操作处进行检查，发现非法状态，再进行破坏估计和错误恢复。

2. 破坏估计

插入断言法是试图在变量状态改变之前对可能引起错误的操作予以避免，而破坏估计的任务是在变量可能已经遭到破坏的情况下，判断破坏是否已发生，以及状态空间的哪些部分受到了错误的影响。例如，在抽象数据类型中，可以设置一个破坏指示器，通过询问破坏指示器来估计破坏发生的情况。

3. 错误恢复

在防卫式程序设计中，既可使用前向恢复策略，也可使用后向恢复策略，其中后向恢复是一种更易于实现的技术，可以保持一个安全状态的细节，发生错误时再对该状态进行恢复。通常有两种处理办法，一种是数据状态的变换先不写入，等到处理全部完毕而没有出现错误时，才写入变换后的状态，这种处理多用于数据库系统中；另一种是在一定时间间隔的检查点制作安全状态的备份，当发生错误时，恢复最近检查点的状态。

防卫式程序设计是一种较易实现的方法，比较灵活，尤其适用于小程序或局部程序的容错。尽管防卫式程序设计不能处理算法中存在的逻辑错误，但对程序运行过程中出现的硬件故障或偶然事件引起的错误能起到屏蔽的作用，并且由于其执行效率高、占用空间小、易于设计和实现，因此，是对恢复块方法和多版本程序设计技术的一个补充。